CODE OF PRACTICE TEMPLATE

Note: The title of the code of practice is subject to the NCII sector lead preparing the code of practice.

Suggested Title:

CODE OF PRACTICE FOR NATIONAL CRITICAL INFORMATION INFRASTRUCTURE (NCII) ENTITIES DESIGNATED BY THE [INSERT NAME OF NCII SECTOR LEAD] UNDER THE [INSERT NCII SECTOR] NCII SECTOR

Example:

CYBER SECURITY CODE OF PRACTICE FOR NATIONAL CRITICAL INFORMATION INFRASTRUCTURE (NCII) ENTITIES DESIGNATED BY THE MINISTRY OF FINANCE UNDER THE BANKING AND FINANCE NCII SECTOR

CoP TEMPLATE

NOTE: ***This document serves as an example for NCII sector lead to develop sector specific code of practice. NCII sector leads who develop their sector specific CoP using this template may refer to the examples in this document for guidance and customise it to align with the specific context of their sector and take into consideration the following matters when preparing the CoP:***

1. ***the functions of the relevant NCII entities.***
2. ***provisions relating to cyber security under any other written law applicable to the NCII sector lead.***
3. ***the views of the relevant NCII entities.***
4. ***the views of the relevant regulatory authority, if any, which the NCII entity is subject to.***

Table of Contents

DEFINITION I

1.0 PURPOSE 1

2.0 LEGAL EFFECT OF THIS CODE OF PRACTICE 1

3.0 APPLICATION AND SCOPE 2

4.0 GOVERNANCE AND LEADERSHIP 2

5.0 CYBER SECURITY POLICY AND OBJECTIVES 3

6.0 ORGANISATIONAL DEVELOPMENT 6

7.0 CYBER SECURITY ASSURANCE 10

8.0 RESOURCE ALLOCATION AND OPTIMISATION 17

9.0 RISK MANAGEMENT 21

10.0 OPERATIONAL EFFICIENCY 25

11.0 DATA SECURITY 26

12.0 CONTRACTUAL MANAGEMENT 32

13.0 PHYSICAL SECURITY 34

14.0 SYSTEM AND NETWORK SECURITY 37

15.0 ACCESS CONTROL 43

16.0 TECHNICAL VULNERABILITY 48

17.0 CYBER SECURITY EVENT MANAGEMENT 52

18.0 CYBER SECURITY INCIDENT MANAGEMENT 53

19.0 BUSINESS CONTINUITY MANAGEMENT 57

20.0 [OTHER SECTOR-SPECIFIC REQUIREMENTS] 61

21.0 MONITORING AND COMPLIANCE 62

22.0 REFERENCES 63

23.0 APPENDICES 64

CoP TEMPLATE

DEFINITION

TERMS	DEFINITION
Business Continuity Plan (BCP)	A set of procedures that guide organisations to continue its critical operations during and after a disruption, such as a cyber-attack or disaster, by maintaining the organization's essential functions and sytems and enabling quick recovery.
Data Leakage Protection (DLP)	Strategies, tools, and technologies used to prevent unauthorized access, transmission, or sharing of sensitive or confidential information outside an organization's network, thereby safeguarding against potential data breaches or leaks.
Cyber Security Governance	A process of overseeing and managing an organisation's cyber security efforts by integrating cyber security agendas into established committees, such as management, change management and security steering committees, to ensure effective decision-making and compliance at various approval levels.

Additional definitions can be added as needed to address specific terminology relevant to the subject.

1.0 PURPOSE

The national critical information infrastructure (NCII) sector lead should define the purpose of the Code of Practice (CoP) developed for its NCII entities. The CoP should aim to ensure that NCII entities adopt and implement a cyber security framework that aligns with regulatory requirements and industry best practices. By establishing clear guidelines and minimum security standards through the CoP, it empowers NCII entities to strengthen their cyber resilience, protect NCII infrastructure, and align with the Cyber Security Act 2024 [Act 854], regulations under Act 854, directives of the Chief Executive of the National Cyber Security Agency (NACSA), and the National Cyber Security Baseline (NCSB). The NCII sector lead shall include references to the relevant regulatory requirements and best practices used for NCII compliance, incorporating these references into the checklist as outlined in Appendix A.

This Code of Practice (CoP) establishes cyber security measures, standards and processes for national critical information infrastructure (NCII) entities under [*NCII Sector Lead Name*] of the [*Sector Name*] NCII sector to ensure compliance with the Cyber Security Act 2024 [*Act 854*], regulations under Act 854, directives of the Chief Executive of the National Cyber Security Agency (NACSA) and the National Cyber Security Baseline (NCSB).

This document also includes a checklist (refer to **Appendix A**) that maps relevant regulatory requirements and best practices used for NCII compliance. The checklist serves as a reference for NCII entities to ensure alignment with these standards.

2.0 LEGAL EFFECT OF THIS CODE OF PRACTICE

NCII sector lead should ensure its NCII entities understand and adhere to the legal obligations set forth in this CoP. By establishing clear compliance requirements aligned with Act 854, NCII entities will be held accountable for implementing mandated cyber security measures. Compliance with this CoP not only strengthens national cyber resilience but also mitigates legal and financial risks, ensuring that NCII entities fulfil their responsibilities in protecting NCII infrastructure and maintaining trust with stakeholders.

The CoP is legally binding to the NCII entity upon endorsement by the Chief Executive of NACSA.

CoP TEMPLATE

3.0 APPLICATION AND SCOPE

NCII sector lead should ensure its NCII entities clearly understand the applicability of this CoP within their sector. By outlining the entities and infrastructure covered under this document, the sector lead ensures a consistent and standardised implementation of cyber security measures across all designated NCII entities. This clarity helps NCII entities allocate resources effectively, strengthen cyber resilience, and align their security strategies with national cyber security objectives.

This CoP applies to all NCII entities designated by [NCII Sector Lead Name] of the [Sector Name] NCII sector.

It establishes the minimum cyber security requirements that NCII entities must adhere to in order to safeguard their NCII. The CoP outlines the necessary measures, standards and processes to mitigate cyber risks effectively, ensure operational resilience of the NCII and achieve compliance with Act 854.

4.0 GOVERNANCE AND LEADERSHIP

NCII sector lead should ensure its NCII entities establish strong governance and leadership structures that prioritise cyber security as a strategic imperative. By committing to compliance, NCII entities can enhance their ability to defend against cyber security threats, maintain resilience, and foster stakeholder trust. Effective governance ensures clear accountability, well-defined roles, and sustained commitment from top management, supporting the continuous strengthening of cyber security strategies and ensuring compliance with Act 854.

Governance and leadership are crucial for protecting NCII entities and ensuring compliance with Act 854, fostering trust among stakeholders. Top management must demonstrate commitment to compliance, with roles and responsibilities outlined in Act 854 being assigned and communicated within the organisation.

Clear roles and responsibilities for cyber security at all levels within the organisation shall be established, ensuring that there is accountability for securing the NCII computer and computer systems.

CoP TEMPLATE

5.0 CYBER SECURITY POLICY AND OBJECTIVES

5.1 Cyber Security Policy

NCII sector lead shall ensure its NCII entities establish, implement, and maintain a robust cyber security policy that aligns with industry best practices. By integrating cyber security into organisational governance, allocating necessary resources, and fostering a culture of security awareness, NCII entities will be well-positioned to defend against cyber security threats, enhance resilience, and build trust with stakeholders. Regular review and effective communication of the policy will ensure its continued relevance and effectiveness in addressing evolving cyber risks.

5.1.1 Establishment of the Cyber Security Policy

5.1.1.1 The NCII entity shall establish a cyber security policy that outlines the organisation's overall approach to cyber security, and approved by the relevant cyber security governance committee established for this purpose, as authorised by the management, in accordance with Act 854 and other written laws.

5.1.1.2 This policy should demonstrate the NCII entity's commitment to meeting cyber security requirements and aligning with the organisation's strategic direction.

5.1.2 Alignment with Best Practices

5.1.2.1 The policy shall align with recognised industry standards, best practices and frameworks such as follows, to ensure effectiveness of the policy:

- ISO/IEC 27001:2022 – Information Security, cybersecurity and privacy protection – Information security management systems – Requirements
- ISO/IEC 27002:2022 – Information Security, cybersecurity and privacy protection – Information Security Controls
- The National Institute of Standards and Technology (NIST) Cybersecurity Framework
- Open Web Application Security Project (OWASP) Top 10
- National and sector-specific cyber security regulations

CoP TEMPLATE

5.1.3 Application of the Cyber Security Policy

5.1.3.1 The policy shall be applied across the NCII entity's organisation, including all the NCII owned or operated by the NCII entity as well as all personnel who act on or have access to an NCII.

5.1.4 Review of the Cyber Security Policy

5.1.4.1 The policy shall be reviewed by the relevant team such as the top management and relevant cyber security governance committee established for this purpose, and at least annually and / or whenever significant changes occur such as adoption of new technologies, change made to the design, configuration, security or operation, possession or ceased of the NCII, regulatory requirements or organisational structure impacting cyber security governance (NCII entity no longer owns or operates any NCII).

5.1.4.2 A structured policy review process may include the following:

- Designation of responsible personnel for conducting the review.
- Documenting revisions, justifications, and approvals.
- Version control and change management procedures.

5.1.5 Communication

5.1.5.1 The policy shall be proactively communicated to all relevant stakeholders, through methods of communication such as awareness programs and training sessions, intranet knowledge bases and other methods of communication deemed appropriate.

5.1.5.2 A communication plan may be established to ensure the Cyber Security Policy is disseminated, understood, and enforced across all levels of the organisation.

CoP TEMPLATE

5.2 Cyber Security Objectives

NCII sector leads shall guide its NCII entities in setting measurable, actionable and time bound objectives, to create a robust security environment, implement effective communication across the organisation, establish a structured monitoring, and reporting framework to track progress and continuous improvement through compliance audits.

5.2.1 Development of Cyber Security Objectives

5.2.1.1 The NCII entity shall develop cyber security objectives that are align with its cyber security policy, standards such as Information Security Management System (ISMS), and compliance to the laws and regulations, towards enabling cyber resilience in digitalization.

5.2.1.2 The objectives must be specific, measurable, achievable, relevant and time-bound.

5.2.2 Communication of Cyber Security Objectives

5.2.2.1 The objectives shall be effectively communicated to relevant stakeholders, to ensure awareness, responsibility and accountability.

5.2.2.2 The NCII entity must establish a structured communication plan that ensures all relevant stakeholders understand their roles and responsibilities in achieving cyber security objectives.

5.2.3 Monitoring and Reporting

5.2.3.1 The objectives shall be continuously monitored, tracked and reported annually to the relevant cyber security governance committee established for this purpose, as authorised by the management, through a monitoring and reporting framework.

5.2.3.2 The NCII entity should have a monitoring mechanism to validate compliance with the objectives.

5.2.3.3 A cyber security report shall be submitted to the relevant cyber security governance committee established for this purpose, as authorised by the management, outlining progress towards achieving cyber security objectives, identified areas of concern and resource needs.

CoP TEMPLATE

6.0 ORGANISATIONAL DEVELOPMENT

6.1 Resources (Manpower and Budget)

NCII sector lead shall ensure its NCII entities allocate manpower and budget resources in alignment with their cyber security objectives. Adequate investment in skilled personnel and resources, and well-structured budget, is necessary to safeguard the NCII effectively. The entities need to be well-equipped to defend against cyber security threats, maintain resilience, and uphold trust with stakeholders. These resources will support the NCII entities continued growth.

6.1.1 Definition of Roles and Responsibilities

6.1.1.1 The NCII entity shall establish well-defined cyber security roles and responsibilities that includes:

- Chief Information Security Officer (CISO) / ICT Security Officer (ICTSO) or equivalent
- Cyber security team members (analysts, engineers, incident responders)
- Information Technology (IT) staff (for supporting cyber security functions)

6.1.1.2 Each role shall have a documented description, including job scopes, level of authority and reporting lines.

6.1.2 Communication of Roles and Responsibilities

6.1.2.1 The defined cyber security roles and responsibilities shall be formally documented and communicated to relevant stakeholders, that can be disseminated through the following:

- Employee handbook
- Training sessions
- Security briefings

6.1.3 Allocation of Resources

6.1.3.1 Manpower and financial resources shall be assigned according to the defined cyber security roles and responsibilities.

COP TEMPLATE

6.1.3.2 The NCII entity shall ensure that sufficient qualified personnel are available to effectively implement, manage and maintain cyber security controls.

6.1.3.3 A dedicated cyber security budget shall be allocated to support the implementation of the cyber security strategy that includes the following:

- Cyber security tools (firewalls, antivirus, monitoring systems)
- Training and capacity building
- Cyber security risks, audits and compliance assessments

6.1.4 Review of Resources

6.1.4.1 The allocation of cyber security resources shall be reviewed annually and / or updated as necessary, based on factors such as needs, auditor recommendations, and any relevant considerations by the NCII entity, including the likelihood or impact of risks.

6.1.4.2 Input for the review shall be obtained from the following stakeholders:

- Cyber security team / IT department
- Human Resources department
- Finance department

6.2 Authorities and Special Interest Group

NCII sector lead shall ensure its NCII entities establish and maintain contacts with relevant authorities and special interest group that foster collaboration, trust, and efficient communication among cyber security stakeholders. NCII entities shall regularly update, share, and review these contact list to facilitate effective information sharing and enhance cyber security incident response capabilities.

6.2.1 Establishment of Contacts

6.2.1.1 The NCII entity shall establish contacts with relevant authorities and special interest groups, including:

- National Cyber Coordination and Command Centre (NC4), National Cyber Security Agency (NACSA)
- Royal Malaysia Police (RMP)

CODE TEMPLATE

6.2.1.2 The NCII entity shall maintain an up-to-date list, including direct phone numbers, email addresses, and jurisdiction details of the relevant authorities and special interest groups.

6.2.2 Communication of Contacts

6.2.2.1 The contact information for relevant authorities and special interest groups shall be shared with stakeholders, ensuring all relevant NCII entity employees have access to it for reporting cyber security incidents or seeking cyber security guidance.

6.2.2.2 Communication channels shall be established through medium communication such as information security bulletin / handbook, the NCII entity's intranet portal, Crisis Communication Plan and other medium that is deemed appropriate.

6.2.3 Review of Contacts

6.2.3.1 The list of cyber security authorities and special interest groups shall be reviewed annually and / or in response to significant changes, such as updates to regulatory bodies or industry standards.

6.2.3.2 Any updates to the list must be promptly communicated to all employees to ensure awareness and compliance.

6.3 Cyber Security Awareness and Training

NCII sector lead shall ensure its NCII entities establish cyber security awareness and training plan that is essential to ensure all personnel understand the risks, responsibilities, and best practices related to cyber security. A well-structured training program will equip employees with the knowledge and skills to recognise, respond to, and mitigate potential cyber security threats, ultimately strengthening the organisation's overall security posture. Regular evaluation and assessment of the training programs are necessary to measure their effectiveness and identify areas for continuous improvement.

6.3.1 Establishment of Training Plan

6.3.1.1 The NCII entity shall develop and establish a cyber security awareness and training plan for specific target audience, covering the following topics:

- Social engineering awareness

CCC TEMPLATE

- Cyber hygiene / best practices of the following:
    - authentication procedure/password management
    - clear screen / clean desk
- Cyber security incident reporting procedures
- Safe handling of sensitive data, pertaining to the NCII entity's Data Privacy and Protection Policy

6.3.1.2 The content of the security awareness training program must be reviewed and updated at least annually, or whenever significant changes to the organisation occur.

6.3.1.3 The training plan must be documented and approved by the relevant cyber security governance committee established for this purpose, as authorised by the management.

6.3.2 Conducting Training Programs

6.3.2.1 Cyber security awareness or training programs shall be conducted across the NCII entity at a frequency determined by the organisation. All new employees must complete cyber security awareness training before being granted access to the NCII entity's assets.

6.3.2.2 Awareness and training methods may include:

- Workshop and seminars
- Quizzes
- Infographic posters
- Simulated phishing attacks

6.3.3 Evaluation of Effectiveness

6.3.3.1 Upon each program completion, its effectiveness shall be evaluated using methods such as:

- Post-program assessments (quizzes or tests)

CoP TEMPLATE

- Participant feedback surveys
- Cyber security incident analysis during simulations

6.3.3.2 A pre-program assessment may be conducted to establish a baseline, which will be compared with post-program assessment results.

7.0 CYBER SECURITY ASSURANCE

7.1 IT Acceptable Use Policy

NCII sector lead shall ensure its NCII entities establish and enforce clear guidelines for the responsible and secure use of enterprise IT assets. A well-defined IT Acceptable Use Policy (AUP) helps mitigate cyber risks, prevent misuse, and ensure compliance with regulatory and industry best practices. By outlining acceptable and prohibited behaviours, NCII entities can promote a secure and accountable IT environment. Regular reviews and enforcement mechanisms will ensure that employees remain informed and adhere to the policy, reducing the risk of security breaches and operational disruptions.

7.1.1 Establishment of IT Acceptable Use Policy

7.1.1.1 The NCII entity shall develop and establish a comprehensive IT Acceptable Use Policy (AUP) that outlines the following:

- Acceptable use of enterprise assets
- Prohibited use of enterprise assets
- Personal use of enterprise assets
- Privacy expectations while working with enterprise assets
- Reporting violations of the IT AUP
- Remote work policies
- Bring Your Own Device (BYOD) policy (either enabling or restricting the BYOD)

7.1.1.2 The IT AUP shall align with the sector's industry best practices, standards and regulatory requirements.

CoP TEMPLATE

7.1.2 Application of IT Acceptable Use Policy

7.1.2.1 The IT AUP shall be enforced across the NCII entity through the following recommended means:

- Letter of Undertaking
- Technical configuration

7.1.2.2 The IT support team shall train employees on IT AUP compliance through platforms such as onboarding training and information bulletins.

7.1.3 Review of IT Acceptable Use Policy

7.1.3.1 The IT AUP shall be reviewed and updated when necessary, such as in the following circumstances:

- Emergence of new cyber security threats
- Changes in technology or regulatory requirements
- Identification of gaps from cyber security incidents

7.2 Audit on Cyber Security

NCII sector lead shall establish audit requirements for its NCII entities to ensure compliance with Act 854, its regulations, directives and CoP. Audits on cyber security must be conducted biennially by certified auditors, following an approved plan. Audit findings must be reported to relevant stakeholders, with the final report submitted to the Chief Executive of NACSA within thirty (30) days. Any non-compliance shall be addressed with corrective actions and a clear remediation plan. Regular monitoring and follow-up audits will help strengthen cyber security, reduce risks, and protect critical infrastructure.

7.2.1 Establishment of Audit Plan

7.2.1.1 The NCII entity shall establish an audit plan on cyber security that defines the following:

- Audit scope
- Audit objectives
- Audit methodology

7.2.1.2 The audit plan on cyber security shall be aligned with legal, regulatory, and organisational requirements.

COP TEMPLATE

7.2.1.3 The audit plan on cyber security shall include the frequency of audit, audit criteria, and roles and responsibilities of the auditors.

7.2.2 Approval of Audit Plan

7.2.2.1 The audit plan on cyber security shall be reviewed and approved by relevant cyber security governance committee established for this purpose, as authorised by the management, ensuring the following:

- Alignment with the NCII entity's objectives
- Sufficient allocation of resources (manpower and budgets)
- Compliance to the Act 854

7.2.2.2 Any amendments to the audit plan on cyber security must be documented and re-approved before the implementation.

7.2.3 Conducting the Audit on Cyber Security

7.2.3.1 Audit on cyber security shall be conducted at least once in every two years commencing from the date of designation as NCII entity or at such higher frequency as may be directed by the Chief Executive of NACSA in any particular case as stated in the Cyber Security (Period for Cyber Security Risk Assessment and Audit) Regulations 2024 [*P.U. (A) 219/2024*].

7.2.3.2 The auditor shall be approved by Chief Executive of NACSA to assess the compliance with Act 854 and its regulations, directives of the Chief Executive of NACSA, code of practice, and other cyber security practices adopted by the NCII entity.

7.2.3.3 The audit process shall include document reviews, interviews, system testing, and technical assessments of cyber security controls.

COP TEMPLATE

7.2.3.4 In addition to the mandatory audit on cyber security mandated under subsection 22(1) of Act 854, the NCII entity is encouraged to conduct internal audit on cyber security to proactively identify and mitigate security gaps, enhance compliance readiness, and strengthen overall cyber resilience.

7.2.3.5 When an NCII entity receives a written notice from the Chief Executive directing the NCII entity to conduct an audit in relation to any material changes made to the design, configuration, security, or operation of an NCII, the NCII entity shall carry out such an audit in respect of the NCII, regardless of whether an audit on cyber security has been conducted or carried out under subsection 22(1) of Act 854 in relation to that NCII.

7.2.4 Reporting Findings

7.2.4.1 Audit findings shall be documented in a structured report, highlighting compliance status, gaps, and areas for improvement.

7.2.4.2 The audit report shall be presented and reported to the relevant cyber security governance committee established for this purpose, as authorised by the management and stakeholders.

7.2.4.3 The audit report shall be submitted to the Chief Executive of NACSA within thirty (30) days after the completion of the cyber security audit.

7.2.5 Resolution of Non-Compliance

7.2.5.1 Any non-compliance identified during the audit shall be addressed with corrective and preventive actions.

7.2.5.2 A remediation plan should be created, detailing the necessary steps, assigned personnel, and deadlines for resolution.

7.2.5.3 Progress on remediation efforts shall be monitored, with regular updates provided to the relevant cyber security governance committee established for this purpose, as authorised by the management and relevant stakeholders.

CoP TEMPLATE

7.2.5.4 Follow-up audits may be conducted to ensure the effectiveness of corrective measures.

7.3 Supplier Relationship Security

NCII sector lead shall ensure its NCII entities establish a supply chain management policy to enhance cyber security within supplier relationships. The policy is essential for identifying, assessing and managing cyber security risks associated with external service providers, thereby strengthening the resilience and security of NCII computer and computer systems.

7.3.1 Establishment of Supply Chain Management Policy

7.3.1.1 The NCII entity shall define a Supply Chain Management (SCM) Policy to ensure the following:

- Proactively identify, assess and mitigate cyber security risks associated with supplier relationships that covers internal and external services, processes, network connection, scripts, equipment, business partners.
- Third-party suppliers adhere to a defined cyber security baseline to safeguard the NCII entity's assets and operations.
- Secure handling, storage and transmission of shared confidential data throughout the supply chain.

CoP TEMPLATE

7.3.1.2 The SCM Policy shall include the following:

- Suppliers must demonstrate compliance with recognised security standards such as ISO/IEC 27001 certification or equivalent frameworks.
- The NCII entity engaging external service providers for cyber security services relating to managed security operation centre monitoring and penetration testing shall appoint a cyber security service provider holding a valid license issued under NACSA, in accordance with subregulation 2(1) of the Cyber Security (Licensing of Cyber Security Service Provider) Regulations 2024 [*P.U. (A) 221/2024*]. These requirements do not apply if the cyber security service provider falls under subregulation 2(2) of *P.U. (A) 221/2024*, as follows—
  - The cyber security service is provided by a Government Entity;
  - The cyber security service is provided by a person, other than a company, to its related company; or
  - the computer or computer system in respect of which the cyber security service is provided is located outside Malaysia.
- Supplier agreements shall incorporate cyber security requirements and policies to ensure external parties comply with the NCII entity's security standards. These agreements must include specific contractual terms outlining data protection measures, security assessments and compliance with applicable laws and regulations.

- Establish processes for continuous monitoring and evaluation of supplier adherence to the SCM Policy.

7.3.2 Identification and Documentation of External Service Providers

7.3.2.1 All external service providers handling IT infrastructure, software or sensitive data shall be identified and documented in an external service provider register that documents the following data:

- **Provider Information:** Name, contact details, and role of the service provider.
- **Scope of Services:** Description of the services provided and their relevance to the entity's operations.

CoP TEMPLATE

- **Data Handling:** Specifics of any sensitive or confidential data accessed, processed, or stored by the provider.
- **Risk Level:** Assessment of the cyber security and operational risks associated with the provider.
- **Compliance Status:** Documentation of the provider's adherence to relevant security standards (ISO/IEC 27001) and contractual obligations.
- **Contract Details:** Reference to any agreements or contracts in place, including clauses related to data protection, security requirements, and breach notification.

7.3.3 Review of Supply Chain Management Policy

7.3.3.1 The SCM Policy and external service provider register shall be reviewed annually to ensure ongoing compliance with evolving security standards.

7.3.3.2 The review process shall include, but is not limited to risk reassessment, compliance verification and vendor performance evaluation.

CoP TEMPLATE

8.0 RESOURCE ALLOCATION AND OPTIMISATION

8.1 Asset Management

NCII sector lead shall ensure its NCII entities establish and maintain inventory of all IT assets, with particular emphasis on the NCII computer and computer systems. A well-maintained IT asset inventory is crucial for effective cyber security management, allowing entities to monitor and protect critical assets against potential cyber security threats. Assets within the inventory should be clearly classified which aids in prioritising security resources and ensuring that high-risk assets receive appropriate protection. Each asset must be assigned to a designated owner who is responsible for the asset's security, maintenance, and compliance with organisational policies. Regular reviews and updates of the asset inventory are essential to maintaining its accuracy and relevance.

8.1.1 Establishment of IT Assets Inventory

8.1.1.1 The NCII entity shall establish an IT assets inventory, listing all the computer or computer system as the following:

- End-user devices (desktops, workstations, laptops, smartphones)
- Network devices (wireless access points, switches, firewalls, routers)
- Internet of Things (IoT) devices (printers, smart television)
- Servers (web servers, email servers, application servers)
- Software (operating systems, free software, freeware, open source, in-house, scripts).

8.1.1.2 The inventory shall be centrally managed and updated in an asset management system.

8.1.1.3 Each IT assets shall be recorded with:

- Unique identification number
- Date of acquisition
- Purchase price / Value of assets
- Type and category
- Manufacturer
- Model / Serial number
- Location and assigned department
- Asset owner
- Asset lifecycle status / Warranty expiration date

CoP TEMPLATE

8.1.1.4 In instances where the NCII entity acquires control over a computer or computer system that, in its assessment, qualifies as part of the NCII, the NCII entity shall report this information to the NCII sector lead.

8.1.1.5 If there are any material changes to the NCII following the initial submission of information, where such a change impacts or has the potential to impact the cyber security of the NCII or the NCII entity's ability to respond to cyber security threats or incidents, the NCII entity shall formally notify the NCII sector lead within thirty (30) days from the date of the change's completion.

8.1.2 Maintenance of IT Assets Inventory

8.1.2.1 IT assets inventory shall be maintained and continuously updated to reflect:

- Newly acquired assets
- Decommissioned or retired assets
- Software license validity
- Ownership or department changes

8.1.2.2 A maintenance plan shall be established, incorporating quarterly preventive maintenance and corrective maintenance, along with the associated costs.

8.1.3 Classification and Ownership

8.1.3.1 All IT assets shall be classified based on their value, sensitivity level, and the risks they pose to the NCII entity.

8.1.3.2 Priority shall be given to securing funding and resources to adequately protect these assets, ensuring that risks are effectively mitigated in alignment with their classification.

8.1.3.3 The sensitivity level of an IT assets shall be classified as follows, and labelled accordingly:

- Public

CoP TEMPLATE

- Restricted
- Confidential
- Secret
- Top Secret

8.1.3.4 Each asset shall have an assigned owner responsible for:

- Security controls and compliance.
- Lifecycle management (updates, renewals, decommissioning).
- Cyber security incident reporting related to the asset.

8.1.4 Review of IT Assets Inventory

8.1.4.1 The IT assets inventory shall be reviewed annually and / or whenever changes occur, such as the acquisition of a new systems or the decommissioning of old assets.

8.1.4.2 The review shall validate:

- Asset ownership
- Current status (in use, not in use, damaged, under maintenance, loaned, lost)
- Asset disposal
- Software license validity

8.2 Capacity Management

The NCII sector lead shall ensure its NCII entities establish and implement a capacity management plan to optimise the allocation and scaling of IT resources and infrastructure. NCII entities must regularly review resource utilisation data to identify trends, potential bottlenecks, and areas for optimisation. Based on these insights, resource forecasting should be carried out to estimate future capacity needs. To ensure system resilience and efficiency, performance tests must be conducted to assess the responsiveness, throughput, and stability of IT systems under expected operational conditions.

8.2.1 Establishment of Capacity Management Plan

8.2.1.1 The NCII entity shall establish a Capacity Management Plan that ensures the following:

- IT resources are adequate to meet current and future demands.
- Systems are resilient under peak loads and unexpected surges.

CSA TEMPLATE

- Business continuity planning includes capacity considerations.

8.2.2 Tracking and Monitoring Resource Utilisation

8.2.2.1 IT support team shall continuously track and monitor the resource utilisation of the following:

- CPU and memory usage.
- Network bandwidth consumption.
- Disk space availability.
- Application performance metrics.

8.2.3 Review and Forecasting

8.2.3.1 Resource utilisation shall be reviewed annually, and forecasts shall be developed for:

- Future system growth (new users, additional workloads).
- Infrastructure upgrades (new servers, storage expansions).

8.2.3.2 Resource forecasting shall use historical data and predictive analytics to estimate future IT resource needs.

8.2.4 Performance Tests

8.2.4.1 Performance testing shall be conducted prior to system go-live or whenever required, including after major system changes or based on cyber security risk assessment results to validate and confirm the resilience of the system's performance.

8.2.4.2 Performance tests shall simulate:

- High traffic surges (peak demand periods).
- Data processing loads (large database queries).
- Network congestion scenarios.

CoP TEMPLATE

9.0 RISK MANAGEMENT

9.1 Cyber Security Risk Assessment

NCII sector lead shall ensure its NCII entities implements a structured and effective cyber security risk assessment process. By conducting regular cyber security risk assessments, NCII entities can proactively identify, analyse, and mitigate cyber risks that may impact their critical systems and operations. A well-established cyber security risk assessment framework enables NCII entities to make informed decisions, allocate resources efficiently, and align cyber security strategies with industry best practices and regulatory requirements.

9.1.1 Establishment of Cyber Security Risk Assessment Process

9.1.1.1 The NCII entity shall establish a cyber security risk assessment process to support informed decision-making and the management of cyber security risks.

9.1.1.2 The process shall be formally documented and integrated into the NCII entity's governance framework.

9.1.2 Alignment with Best Practices

9.1.2.1 The cyber security risk assessment process shall align with industry best practices (ISO 27001, NIST 800-53, Information Security Risk Management Guideline (PRKM)).

9.1.2.2 The NCII entity shall adopt recognised methodologies for risk evaluation and mitigation.

9.1.3 Conducting Assessments

9.1.3.1 Cyber security risk assessments shall be conducted annually commencing from the date of designation as NCII entity as stated in the P.U. (A) 219/2024 and whenever significant changes occur (material change made to the design, configuration, security or operation of the entities' NCII, changes of technology and any incident that happened in the past).

CoP TEMPLATE

9.1.3.2 The scope of the cyber security risk assessment conducted shall include an assessment of risks to the computer or computer systems designated as NCII owned or operated by the NCII entity.

9.1.3.3 The cyber security risk assessment shall include the following key steps:

- **Risk Identification:** Proactively identify potential cyber security risks, including assets inventory, cyber security threats, vulnerabilities and potential strategic scenarios on the NCII entity's operations, assets, and stakeholders.
- **Risk Analysis:** Assess the level of risk based on the likelihood and impact of identified risks, taking into account existing controls and their effectiveness.
- **Risk Evaluation:** Evaluate and prioritise risks by comparing the assessed level of risk against the predefined risk criteria established by the NCII entity.

9.1.4 Documentation and Reporting

9.1.4.1 The cyber security risk assessment results shall be documented and reported to the relevant cyber security governance committee established for this, as authorised by the management, and stakeholders including the Chief Executive of NACSA, within the period of thirty (30) days after the completion of the cyber security risk assessment.

9.1.4.2 The report shall be submitted to the Chief Executive of NACSA via e-mail of auditpematuhan@nacsa.gov.my and the NCII entity's sector lead.

9.1.4.3 In cases where the submitted report requires rectification, the Chief Executive of NACSA may determine an alternative timeframe for re-evaluation and re-submission.

9.1.4.4 Cyber security risk reports shall include the following:

- The methodology used in the cyber security risk assessment
- Description of each identified cyber security risk to the NCII
- The likelihood of occurrence and impact of the identified cyber security risks
- The prioritisation of cyber security risks
- The actions to be taken by the NCII entity to address each of the identified risks

CoP TEMPLATE

9.1.5 Risk Prioritisation

9.1.5.1 Identified cyber security risks shall be prioritised based on the level of risks and the NCII entity's acceptance criteria. Risks classified as high shall be addressed with immediate treatment to reduce their impact and likelihood.

9.1.5.2 When evaluating risks against the acceptance criteria, the NCII entity shall consider potential impacts, including reputational damage, legal consequences, financial losses and harm to stakeholders and the organisation as a whole.

9.2 Risk Treatment

NCII sector lead shall ensure its NCII entities effectively manage and mitigate identified cyber security risks. By implementing a structured Risk Treatment Plan (RTP), NCII entities can prioritise and apply appropriate risk treatment strategies, ensuring that cyber security threats are addressed in a systematic and controlled manner. The plan shall be approved and implemented according to its outlined arrangement. NCII entities shall document and report the results of the risk treatment. To ensure consistency in reporting, the NCII sector lead may specify a standardised report format in the CoP for NCII Entities to follow.

9.2.1 Formulation of Risk Treatment Plan

9.2.1.1 The NCII entity shall formulate a Risk Treatment Plan (RTP) that outlines prioritised actions based on the level of risk and the urgency of treatment required.

9.2.1.2 For each identified cyber security risk within the RTP, detailed implementation information shall be monitored and documented. This information shall include, but is not limited to:

- **Risk treatment option:** Option for risk treatment may include risk retention, risk modification, risk sharing and risk avoidance.
- **Risk treatment controls:** Specific measures or actions to mitigate the risk.
- **Designation of risk owners:** Individuals or teams accountable for managing the risk.
- **Designation of persons responsible for implementation:** Individuals or teams tasked with executing the treatment activity.
- **Residual risk:** The level of risk remaining after the implementation of treatment controls.

CoP TEMPLATE

9.2.2 Approval of Plan

9.2.2.1 The RTP shall be reviewed and approved by the relevant cyber security governance committee as authorised by management, prior to implementation.

9.2.2.2 To grant approval, the risk owners shall evaluate the proposed controls outlined in the RTP to assess their effectiveness in mitigating the likelihood and/ or the impact of the identified risks.

9.2.3 Implementation of Plan

9.2.3.1 The approved RTP shall be implemented and the implementation effectiveness should be continuously monitored and reviewed during the meetings of relevant cyber security governance committee established for this purpose, as authorised by the management.

9.2.3.2 Progress on the execution of the plan shall be reported periodically, with clear status updates categorised as:

- **Not Started:** Tasks or controls that have yet to be initiated.
- **In Progress:** Tasks or controls currently being implemented.
- **Completed:** Tasks or controls that have been fully executed.

9.2.4 Documentation and Reporting

9.2.4.1 The results of the cyber security risk treatment shall be documented and reported to the relevant cyber security governance committee established for this purpose, as authorised by the management, and / or stakeholders.

9.2.4.2 The report should include, but not limited to, the following:

- The necessary controls for risk treatment; and
- The evidence demonstrates that these controls effectively mitigate risks to align with the NCII entity's risk acceptance criteria (where applicable and feasible).

CoP TEMPLATE

10.0 OPERATIONAL EFFICIENCY

10.1 Change Management

NCII sector lead shall ensure its NCII entities establish and maintain a comprehensive change management procedure to implement changes in a controlled and secure manner. All changes must be subject to formal authorisation processes to ensure security and compliance. This structured approach aims to enhance the NCII entities' security posture by minimizing risks associated with misconfigurations, security vulnerabilities, and compliance violations.

10.1.1 Establishment of Change Management Procedure

10.1.1.1 The NCII entity shall establish a Change Management Procedure to ensure structured and controlled changes to information processing facilities, information systems and other relevant IT components.

10.1.1.2 The procedure shall outline:

- Change request submission and documentation.
- Assessment of risks and impact.
- Testing and validation steps.
- Implementation and rollback strategies.

10.1.2 Application of Change Management Procedure

10.1.2.1 The change management procedure shall be enforced across all NCII entity to maintain system stability and security.

10.1.2.2 All changes shall be tracked in a centralised system for accountability.

10.1.2.3 Emergency changes shall require expedited approvals and post-implementation reviews.

10.1.3 Authorisation for Changes

10.1.3.1 Any changes to information processing facilities, information systems or other relevant IT components, shall require formal authorisation from system owners prior to implementation.

COP TEMPLATE

10.1.3.2 Authorisation shall be granted based on:

- Risk level.
- Business impact.
- Security implications.

10.1.4 Review of Change Management Procedure

10.1.4.1 The change management procedure shall be reviewed annually and / or when significant changes occur.

10.1.4.2 Reviews shall assess:

- Effectiveness of the change control process.
- Compliance with security and operational policies.
- Efficiency of the approval and rollback mechanisms.

11.0 DATA SECURITY

11.1 Data Leakage Prevention (DLP)

NCII sector lead shall ensure its NCII entities implement and maintain a Data Leakage Prevention (DLP) solution to safeguard data from unauthorized access, loss, or leakage. This approach will help maintain the integrity, regulatory compliance, and cyber security resilience of the NCII entities. The DLP solution should include policies, tools, and strategies to detect, prevent, and respond to unauthorized data transfers or exfiltration. It must monitor data in use (endpoints), data in motion (network traffic), and data at rest (storage) to prevent accidental or intentional data leaks. DLP logs should integrate with the Security Information and Event Management (SIEM) tool and other relevant solutions to enhance cyber security threat detection, analysis, and incident response.

11.1.1 Implementation of DLP Solution

11.1.1.1 The NCII entity shall implement a DLP solution across its organisation, to safeguard sensitive data from unauthorised access, leakage, or theft.

11.1.1.2 The DLP solution shall include:

- Endpoint protection for monitoring data transfers via devices (USB, external drives).

COP TEMPLATE

- Network protection to inspect data transfers via email, file sharing, or cloud uploads.
- Data classification to identify and tag sensitive data (PII, intellectual property).

11.1.2 Maintenance of DLP Solution

11.1.2.1 Regular maintenance shall be applied to the DLP solution.

11.1.2.2 Maintenance activities include:

- Regular audit, review and update DLP policies to address emerging cyber security threats.
- Reviewing DLP incidents to assess and refine protection strategies.
- Updating data classification schemes to include new types of sensitive information.
- Staff training and awareness.

11.1.3 Integration with Security Information and Event Monitoring (SIEM)

11.1.3.1 NCII entity shall ensure that DLP logs is integrated seamlessly with the SIEM tool to:

- Provide centralised monitoring and analysis of cyber security incidents.
- Facilitate correlation of events to detect suspicious patterns.
- Enhance cyber security incident response capabilities through automated alerts and escalations.

11.2 Data Privacy and Protection

NCII sector lead shall ensure its NCII entities safeguard the privacy, integrity, and confidentiality of sensitive data throughout its lifecycle. By implementing and maintaining a structured Data Privacy and Protection Procedure, NCII entities can mitigate the risks of unauthorized access, data breaches, and regulatory non-compliance. Regular monitoring, audits, and staff training will reinforce compliance and enhance the resilience of NCII entities in protecting critical data assets.

CSB TEMPLATE

11.2.1 Establishment of Data Privacy and Protection Procedure

11.2.1.1 The NCII entity shall define a comprehensive procedure for managing data privacy and protection, including data management lifecycle as follows:

- **Data acquisition:** When acquiring data, the NCII entity must consider storage solutions and security requirements that are commensurate with the type of data collected.
- **Data inventory:** The IT department must conduct an inventory of data on an annual basis. All sensitive data must be marked accordingly in the inventory. Components of a data inventory may include the data type, data owner, data classification, data location, data format and data retention. Data backup is crucial, and the appropriate data to back up must be identified by utilising the data inventory to support the identification process.
- **Data classification:** The NCII entity should determine what data is considered sensitive based on legal, regulatory, or business requirements as well as potential risk posed should data be compromised or lost.
- **Data protection:** IT department must configure access control lists on NCII entity's assets in accordance with user's need to know. Sensitive data should be encrypted when in transit or at rest on servers, applications and databases.
- **Data handling:** The NCII entity should properly secure the data throughout the whole lifecycle including the processing, storage, and transmission of the data, in accordance with data sensitivity. All data and documents must be preserved for the appropriate amount of time as dictated by regulatory, legal, and business requirements.
- **Data disposal:** Authorised parties must destroy data that have outlasted their specified retention timeframes. Whenever possible, the enterprise should ensure that contracts with third-party services providers include clauses to destroy all company data at the request of the enterprise. Ensure that the disposal process and method are appropriate for the sensitivity of the data.

CoP TEMPLATE

11.2.2 Alignment with Legal and Regulatory Requirements

11.2.2.1 The data privacy and protection procedure shall comply with applicable laws, regulatory and business requirements, such as:

- Personal Data Protection Act 2010 [*Act 709*] (PDPA);
- Official Secrets Act 1972 [*Act 88*];
- other relevant regulations; and
- Sector-specific guidelines for data privacy and protection.

11.2.3 Application of Data Privacy and Protection Procedure

11.2.3.1 The procedure shall be applied across the NCII entity that covers:

- All operational processes involving personal or sensitive data, from acquisition to disposal.
- Third-party engagements with third parties, including vendors, contractors, and partners, ensuring data sharing and processing agreements comply with the organisation's policy.
- Include data protection clauses in all contracts and conduct regular assessments of third-party compliance.

11.2.4 Monitoring Compliance

11.2.4.1 Compliance with the data privacy and protection procedure shall be regularly monitored, through audits and assessments of the data privacy and protection practices.

11.2.4.2 Monitoring shall include:

- Data access logs to detect unauthorised activities.
- Assessments of access controls.
- Periodic staff training to reinforce compliance awareness.

CoP TEMPLATE

11.2.5 Review of Data Privacy and Protection Procedure

11.2.5.1 The procedure shall be reviewed at least annually and / or whenever necessary, such as:

- Adoption of new technologies or data processes.
- Updates to applicable laws or regulations.
- Changes to the organization's structure, processes, or risk profile.

11.2.5.2 Record of all reviews, including findings, recommendations, and implemented changes shall be maintained.

11.2.5.3 Ensure that historical versions of the procedure are retained for reference and audit purposes.

11.3 Software and Application Security

NCII sector lead shall ensure its NCII entities mitigate security risks by establishing comprehensive cyber security guidelines that govern the development, acquisition, and deployment of software and system / applications. The implementation of these cyber security measures strengthens the NCII entities defence against potential cyber security threats while ensuring cyber security resilient and the confidentiality, integrity, and availability of its software and system / application.

11.3.1 Establishment of Guidelines

11.3.1.1 The NCII entity shall establish cyber security guidelines for the development of software and system / application that covers, but not limited to the following:

- Secure coding practices that align with recognised security guidelines (OWASP Top 10).
- Access control mechanisms within applications.
- Requirements for regular updates and patches.

11.3.2 Implementation of Guidelines

11.3.2.1 The guidelines shall be enforced during the acquisition of software and system / application, either through the software development lifecycle (SDLC) stages or the procurement of third-party software solutions.

COP TEMPLATE

11.3.3 Requirement Identification, Specification and Approval

11.3.3.1 Cyber security requirements for each software and system / application shall be identified and specified during development or acquisition process. These requirements shall be reviewed and approved by the relevant cyber security governance committee as authorised by management for this purpose.

11.3.4 Security Testing

11.3.4.1 The NCII entity shall ensure security testing on software and system / application are conducted during development followed by penetration testing prior to deployment in a production environment and public facing.

11.3.4.2 Pre-deployment security testing shall include:

- Vulnerability scans to detect weaknesses.
- Penetration testing to simulate attack scenarios.
- Validation of compliance with secure coding guidelines.

11.4 Secure Configuration

NCII sector lead shall ensure its NCII entities establish and maintain secure configuration baselines for all hardware, software, services, and networks. By implementing a structured configuration procedure, NCII entities can mitigate security vulnerabilities, enforce consistent security settings, and reduce the risk of cyber security threats due to misconfigurations. Logs and audit trails will support forensic investigations and regulatory compliance, strengthening the overall security posture of NCII entities.

11.4.1 Establishment of Configuration Procedures

11.4.1.1 NCII entity shall establish a configuration procedure that defines the baseline for the technologies used across the following asset categories before they are deployed by the NCII entity:

- Hardware
- Software
- Services
- Networks

COP TEMPLATE

11.4.1.2 In the event of the unavailability of the configuration guidelines for a specific technology, the NCII entity's IT department must research and determine the appropriate security configurations, and develop a configuration template before deploying the product.

11.4.2 Monitoring and Approval

11.4.2.1 Technologies with secure configurations shall be continuously monitored and reviewed to ensure ongoing compliance with approved settings.

11.4.2.2 The approved secure configuration guidelines for a technology must be promptly updated following any significant updates. The criteria for determining "significant" updates shall be established based on industry standards and defined thresholds.

11.4.2.3 Any significant updates and installations shall be approved by the relevant cyber security governance committee established for this purpose, as authorised by the management.

11.4.3 Logs Maintenance

11.4.3.1 The configuration logs shall be able to record all changes, approvals, cyber security incidents and audit activities.

11.4.3.2 The logs must be securely maintained to support regulatory compliance and forensic investigations. This can be achieved by retaining the data retention for a defined period (e.g. five (5) years) as determined by the relevant cyber security governance established for this purpose.

CoP TEMPLATE

12.0 CONTRACTUAL MANAGEMENT

12.1 Non-Disclosure Agreement (NDA)

NCII sector lead shall ensure its NCII safeguard their confidential information and ensuring compliance with legal and regulatory requirements. A key aspect of this process is the establishment and enforcement of Non-Disclosure Agreements (NDAs) to protect sensitive data shared with internal and external stakeholders.

12.1.1 Establishment of NDAs

12.1.1.1 The NCII entity shall establish NDAs and develop standardised agreement templates to ensure consistency and compliance with legal requirements. These templates must:

- Define confidential information (customer data, project details).
- Specify the obligations of parties (protection, non-sharing, and non-disclosure of information).
- Outline the permitted use of confidential information (use strictly for intended purposes).
- Include consequences for breaches of confidentiality.

12.1.1.2 NDAs shall be complied with:

- Legal and regulatory requirements.
- Industry standards and best practices.

12.1.2 Signing of NDAs

12.1.2.1 NDAs shall be signed by all relevant parties before sharing or granting access to sensitive information. This includes:

- Internal stakeholders (employees, contractors, interns).
- External stakeholders (vendors, suppliers, business partners).

12.1.2.2 A designated authority or legal representative within the NCII entity shall:

- Ensure that all parties understand their responsibilities and obligations.
- Verify that signed agreements are stored securely in a centralised repository.
- Only authorised personnel should have access to these documents to prevent unauthorized modifications or breaches.

CoP TEMPLATE

12.1.3 Monitoring and Reporting Compliance

12.1.3.1 The NCII entity shall monitor compliance with signed NDAs through:

- Regular audits and reviews of information-sharing practices.
- Implementation of access controls to track and log the flow of confidential information.
- Periodic re-confirmation of NDA obligations with long-term collaborators or employees.

12.1.3.2 Instances of non-compliance shall be reported to the relevant cyber security governance committee established for this purpose, as authorised by the management, for further action.

13.0 PHYSICAL SECURITY

13.1 Physical Security Procedure

NCII sector lead shall ensure its NCII entities establish and maintain physical security procedures to protect their premises, personnel, and assets. These procedures must include safeguards to prevent unauthorized access, reduce risks to physical infrastructure, and ensure the safety of employees and sensitive assets. Regular monitoring and compliance checks must be conducted to keep security standards up-to-date and effective, thereby supporting operational integrity and ensuring compliance with regulatory requirements.

13.1.1 Establishment of Physical Security Procedure

13.1.1.1 The NCII entity shall establish a comprehensive physical security procedure to safeguard its premises, personnel, and assets.

13.1.1.2 The procedure shall address:

- Access control mechanisms (ID badges, biometric systems).
- Surveillance and monitoring (CCTV, security personnel).
- Visitor management processes (visitor logs, escort policies).
- Emergency response plans (fire drills, evacuation routes).

COP TEMPLATE

13.1.2 Alignment with Best Practices

13.1.2.1 The physical security procedure shall adhere to industry standards and best practices, such as:

- ISO 27001 for information security management.
- National Fire Protection Association (NFPA) standards for fire and life safety.
- Local and international legal regulations for physical safety and security.

13.1.3 Application of Physical Security Procedure

13.1.3.1 The physical security procedure shall be implemented across all NCII entity's premises, including:

- Headquarters and branch offices.
- Data centres and server rooms.
- Storage areas for sensitive documents or equipment.

13.1.3.2 Employees, contractors, and visitors shall be trained and informed about the procedure to ensure compliance.

13.1.4 Monitoring Compliance

13.1.4.1 Compliance with the physical security procedure shall be monitored through:

- Regular inspections and audits of facilities.
- Access control system logs to track entry and exit activities.
- Reports from security personnel or surveillance systems.

13.1.4.2 Any instances of non-compliance shall be documented and addressed promptly.

13.1.5 Review of Physical Security Procedure

13.1.5.1 The physical security procedure shall be reviewed annually as part of routine organisational assessments, and / or whenever significant changes occur, such as relocation, expansion, or new risks.

13.1.5.2 Reviews shall involve relevant stakeholders, including:

- Security teams.

CoP TEMPLATE

- Facilities management.
- Legal and compliance officers.

13.2 Security Perimeters

NCII sector lead shall ensure that its NCII entities' physical security perimeters are established to prevent unauthorised access, damage, and interference with the NCII's information. Security perimeters should be designed to ensure clear distinctions between public, restricted, and high-security areas, supported by access control mechanisms, surveillance systems, and preventative measures to safeguard personnel and infrastructure. Continuous monitoring and maintenance of the security perimeters ensure a proactive stance against potential security breaches, while regular assessments help adapt the perimeters to evolving security needs.

13.2.1 Establishment of Security Perimeters

13.2.1.1 The NCII entity shall establish security perimeters to prevent unauthorised physical access, damage and interference to the NCII's information.

13.2.1.2 The security perimeters may include the following:

- Outer perimeters (fences, gates).
- Internal perimeters (restricted access zones, server rooms).
- High-security zones (areas with sensitive or classified information).

13.2.1.3 Clear signage shall indicate authorised access zones and restricted areas.

13.2.1.4 Entry points shall be equipped with:

- Locks, turnstiles, or electronic access systems.
- Video surveillance and alarms for unauthorised access attempts.

13.2.2 Monitoring

13.2.2.1 Continuous monitoring of the NCII entity's premises shall be implemented to prevent unauthorised physical access such as the following:

- CCTV systems shall cover all critical and restricted areas, with footage archived for at least thirty (30) days or as required by policy.
- Security personnel shall conduct regular patrols and maintain logs of their observations.

COP TEMPLATE

- Visitor and access logs shall be reviewed periodically to detect irregularities.

13.2.3 Protection against Threats

13.2.3.1 The NCII entity shall design and implement measures to protect against physical and environmental threats to reduce the consequences of unwanted events, such as:

- Natural disasters (floods, earthquakes):
  - Use of reinforced structures.
  - Emergency evacuation plans.
- Fire hazards:
  - Fire detection and suppression systems (sprinklers, extinguishers).
  - Regular fire drills and training.
- Theft or vandalism:
  - Secure storage of valuable assets.
  - Alarm systems for unauthorised entry.

13.2.3.2 A risk assessment shall be conducted regularly to identify potential threats and implement corresponding mitigation measures.

14.0 SYSTEM AND NETWORK SECURITY

14.1 Network Security Policies and Procedures

NCII sector lead shall ensure that its NCII entities' network security is governed by a comprehensive policy and well-defined procedures. The policies should cover key aspects of network security, including access controls, encryption standards, cyber security incident response procedures, and network segmentation, aligning with best practices and relevant industry standards. Regular audits and automated compliance tracking provide mechanisms for ongoing monitoring, while periodic reviews ensure the network security measures remain robust and adaptive to new cyber security threats and changes in the infrastructure.

14.1.1 Establishment of Network Security Policy and Procedure

14.1.1.1 The NCII entity shall develop and document a comprehensive network security policy and procedure to protect network infrastructure and maintain secure operations.

CC TEMPLATE

14.1.1.2 The policy and procedure shall address enforcement of access controls based on authentication and least privilege principles, using models like Role-based Access Control (RBAC), Attribute-based Access Control (ABAC), or other relevant approaches suited to the NCII entity's needs.

14.1.1.3 Key stakeholders, including IT teams and security personnel, shall be involved in the drafting process.

14.1.2 Review and Approval

14.1.2.1 The network security policy and procedure shall be reviewed and approved by the relevant cyber security governance committee as authorised by management for this purpose, to ensure:

- Organisational alignment and resource allocation.
- Accountability for enforcement at all levels.

14.1.3 Alignment with Industry Best Practices

14.1.3.1 The network security policy and procedure shall adhere to industry standards and best practices such as:

- ISO 27001: Information Security Management.
- NIST Cybersecurity Framework.

14.1.4 Monitoring Compliance

14.1.4.1 Compliance with the network security policy and procedure shall be monitored through:

- Regular internal audits and assessments.
- Usage of automated tools to track policy adherence.
- Reporting of violations or deviations from the policy.

14.1.5 Review of Network Security Policy and Procedure

14.1.5.1 The network security policy and procedure shall be reviewed annually as part of the NCII entity’s security assessments, and / or when significant changes occur in the network or cyber security threat landscape.

CoP TEMPLATE

14.2 Physical and Logical Network Diagrams

NCII sector lead shall ensure its NCII entities establish and maintain a physical and logical network diagrams for a clear understanding of the network infrastructure. Physical diagrams represent hardware, cabling, and device locations, while logical diagrams illustrate network segmentation, IP addressing, and data flows. Regular reviews and updates ensure the diagrams reflect any changes to network components or security configurations.

14.2.1 Establishment of Physical and Logical Network Diagrams

14.2.1.1 The NCII entity shall define and maintain physical and logical network diagrams that include:

- Physical diagrams: Representation of hardware, cabling, and device locations.
- Logical diagrams: Network segmentation, IP addressing, and data flows.

14.2.1.2 These diagrams shall provide a comprehensive understanding of the network architecture.

14.2.2 Alignment with Best Practices

14.2.2.1 Network diagrams shall be aligned with industry standards and best practices such as NIST SP 800-115, to ensure clarity, accuracy and effectiveness in troubleshooting and strategic planning.

14.2.3 Inclusion of Advanced Security Controls

14.2.3.1 The diagrams shall include advanced security controls, such as:

- Next-generation firewalls (NGFW): For application-aware traffic filtering.
- Intrusion Detection and Prevention Systems (IDPS): For detecting and mitigating cyber security threats.
- SIEM: For real-time monitoring and analysis.
- Zero Trust Architecture: To ensure granular access controls.

CoP TEMPLATE

14.2.4 Review of Physical and Logical Network Diagrams

14.2.4.1 Network diagrams shall undergo review and updates by the relevant cyber security governance committee, as authorised by the management, when changes occur, including:

- The addition of new network components.
- Modifications to security controls.

14.3 Network Security Controls

NCII sector lead shall ensure its NCII entities has a network security controls in place to protect their network infrastructure from unauthorised access, attacks, and data breaches. Effective controls, such as firewall rules, Intrusion Prevention Systems (IPS), and Network Access Control (NAC) solutions, are critical in managing and mitigating risks within the network environment. The network security controls shall undergo regular reviews, both annually and following any significant network changes or incidents, to ensure their continued effectiveness and to adapt to evolving cyber security threats.

14.3.1 Firewall Rules Implementation

14.3.1.1 The NCII entity shall implement firewall rules to control traffic between network segments by:

- Enforcing traffic segmentation between different network zones.
- Blocking unauthorised ports and protocols.
- Regularly updating firewall rules to address emerging cyber security threats.

14.3.2 Network Threat Detection Capability

14.3.2.1 The NCII entity shall implement network threat detection capability to ensure timely detection and response to suspicious network activities to prevent and mitigate cyber security threats. This includes the use of a Web Application Firewall (WAF) for all external-facing applications to mitigate common attack vectors.

14.3.2.2 Threat detection capabilities shall be tested and refined regularly to adapt to evolving cyber risks.

CoP TEMPLATE

14.3.3 Network Access Control (NAC) Solutions

14.3.3.1 The NCII entity shall implement NAC solutions across the organisation to enforce access policies, including:

- Device authentication and authorisation before granting network access.
- Quarantining non-compliant devices.
- Segmentation based on device risk levels.

14.3.4 Review of Network Security Controls

14.3.4.1 Firewall rules, network threat detection capability, and NAC solutions shall be reviewed annually to ensure they align with security needs, and / or whenever necessary, such as after major network updates or incidents.

14.4 Malware Detection and Prevention

NCII sector lead shall ensure its NCII entities implement robust measures to safeguard against malicious applications, code, or scripts that can compromise IT assets. This includes deploying malware detection and prevention software, integrating with Security Information and Event Management (SIEM) systems for real-time monitoring and automated cyber security threat response, and conducting regular analysis to maintain effectiveness against emerging cyber security threats. Effective malware detection and prevention measures are essential to protect IT infrastructure, sensitive information and operational continuity.

14.4.1 Implementation of Malware Detection and Prevention Software

14.4.1.1 Malware detection and prevention software shall be deployed across all endpoints, servers, and network devices to prevent or control the installation, spread and execution of malicious applications, code or scripts on the NCII entity's assets.

14.4.1.2 Features of the malware detection and prevention software shall include:

- Real-time scanning for malware and viruses.
- Automatic updates.
- Quarantine or removal of malicious files.

CoP TEMPLATE

14.4.1.3 NCII entities user must not disable the malware detection and prevention software on their assets.

14.4.1.4 The software must be configured to automatically update and IT support must ensure that the malware signatures are kept up-to-date as they become available.

14.4.2 Integration with Security Information and Event Monitoring (SIEM)

14.4.2.1 Logs from malware detection and prevention software shall be integrated with tools, such as SIEM, that enable centralised monitoring and correlation of events to detect sophisticated attacks.

14.4.3 Regular Analysis and Evaluation

14.4.3.1 Logs generated by the malware detection and prevention software shall be regularly analysed for patterns or anomalies, and evaluated for emerging malware trends or tactics.

14.4.3.2 Identified malware must be removed from the NCII entity's assets.

CoP TEMPLATE

15.0 ACCESS CONTROL

15.1 Identity and Access Management (IAM)

NCII sector lead shall ensure its NCII entities implement an Identity Access Management (IAM) procedures to secure and control access to systems, data, and resources. The IAM procedure shall define account types, enforce Multi-Factor Authentication (MFA), and monitor compliance with established policies. Regular reviews, approvals, and periodic audits shall be conducted to maintain effectiveness, align with organizational goals, and minimize risks associated with unauthorized access.

15.1.1 Establishment of Identity and Access Management Procedures

15.1.1.1 The NCII entity shall define and implement an Identity and Access Management (IAM) procedure that includes:

- Types of accounts and credential management that such as:
  - **Administrative accounts:** Also referred to as superuser, privileged, or root accounts, these accounts possess extensive permissions to control and manage operating systems, applications, and platforms.
  - **User accounts:** These accounts are normally used by employees and contractors to perform their day-to-day work tasks. While they typically have limited privileges compared to administrative accounts, they still require proper oversight to ensure they are not misused or compromised.
  - **Vendor accounts:** These accounts are created by the vendor of a technology, such as a firewall or cloud platform. Vendor accounts may or may not have administrative privileges. They are often pre-configured and may come with default credentials that are widely known, creating potential access vulnerabilities if not properly secured or updated.
  - **Default accounts:** Default accounts are frequently pre-installed on systems or applications and often come with well-known usernames and passwords. These accounts can serve as backdoors if not properly managed or disabled. While some default accounts may be vendor-specific, others may be intended for general use. It is critical to change default credentials immediately and disable any unnecessary default accounts to reduce security risks.

COP TEMPLATE

- Implementation of Multi-Factor Authentication (MFA) to protect against unauthorised access. The following requirements outline the use of MFA across various access scenario:
    - **Externally / Internet facing applications**: All applications that are externally accessible must enforce MFA. This includes applications accessed by employees, contractors, or external users.
    - **Remote network access**: MFA must be required for all remote access to the NCII entity's network. This applies to virtual private network (VPN) connections, remote desktop protocols (RDP) and any other methods of remote access.
    - **Administrative access account:** MFA must be enforced for all administrative access accounts, where supported, across all critical assets. This includes systems and applications managed on-site or through third-party service providers.

15.1.2 Review and Approval

15.1.2.1 The IAM procedure shall be reviewed and approved by the relevant cyber security governance committee as authorised by the management for this purpose, ensuring alignment with the NCII entity's organisational goals and adequate allocation of resources for effective implementation.

15.1.2.2 Approval documentation should be maintained with a revision history to facilitate easy tracking of changes.

15.1.3 Monitoring Compliance

15.1.3.1 Compliance with the IAM procedure, including the provision, revocation and modification of identities shall be regularly monitored to ensure adherence to established policies and controls.

CoP TEMPLATE

15.1.3.2 Key compliance monitoring activities may include:

- Conducting periodic audits to verify that identity provisioning, modification and access rights are granted in accordance with the principle of least privilege.
- Monitoring user activity logs to detect and respond to unauthorised access attempts or anomalies.
- Ensuring that access is promptly modified or revoked for employees, contractors, or third parties who no longer require it (due to role changes or termination).
- Utilising automated tools or systems, where feasible, to streamline compliance monitoring, identity lifecycle management, and reporting.

15.1.4 Review of Identity and Access Management Procedures

15.1.4.1 The IAM procedure shall be reviewed at least annually and / or whenever significant changes occur, such as organisational restructuring or updates in access policy.

15.1.4.2 The review process should include the following activities:

- Evaluate the effectiveness of current IAM controls and identify areas for improvement.
- Update the IAM procedure to address any gaps or changes in the organization's environment.
- Obtain approval from the relevant cyber security governance committee, as authorised by the management approval, for any revisions to the IAM procedure.
- Communicate updates to relevant stakeholders and ensure proper implementation.

CoP TEMPLATE

15.2 Segregation of Duties

NCII sector lead shall ensure its NCII entities implement measures to prevent fraud, conflicts of interest, errors, misuse of organizational resources, and unauthorized activities. This includes establishing clear roles and responsibilities, enforcing segregation of duties to minimize risks, and conducting regular reviews to ensure duties and responsibilities remain aligned with operational needs. These practices help safeguard sensitive data, maintain transparency, enhance security, and promote accountability within the NCII entity.

15.2.1 Segregation of Duties and Responsibilities

15.2.1.1 The NCII entity shall segregate the duties and responsibilities of employees based on their roles.

15.2.1.2 Duties and responsibilities shall be segregated to:

- Minimise the risk of unauthorised or fraudulent activities.
- Avoid conflicts of interest by ensuring no individual has complete control over critical processes.
- Prevent blame-shifting by ensuring clear roles definition.

15.2.1.3 Examples of segregation of duties include:

- Separating the roles of developers and system administrators in software projects.
- Ensuring that employees who approve transactions are not the same as those who process them.

15.2.2 Defined Roles and Provision

15.2.2.1 The NCII entity shall clearly define provision roles and responsibilities to ensure:

- Employees are granted appropriate access levels based on their job roles.
- Smooth transitions during role removal or reassignment by predefining and provisioning access requirements.
- Miscommunication and inconsistencies in access provisioning are avoided.

CoP TEMPLATE

15.2.2.2 Roles shall be mapped to business processes, and any discrepancies in access provisioning shall be promptly identified and resolved to prevent unauthorised or excessive access.

15.2.3 Review of Duties and Responsibilities

15.2.3.1 Segregation of duties shall be reviewed annually, as part of access control audits, and / or whenever there are organisational changes, such as mergers, acquisitions, or role restructurings.

15.3 Password Management

NCII sector lead shall ensure its NCII entities enforce strong authentication measures and protect sensitive data by implementing a Password Management System (PMS). The PMS shall align with industry best practices, mitigate risks of unauthorized access and credential-based attacks, and include compliance monitoring to ensure adherence to the password policy. Regular reviews of the PMS shall be conducted to maintain its effectiveness and adapt to evolving security needs.

15.3.1 Establishment of Password Management System (PMS)

15.3.1.1 The NCII entity shall establish a PMS by:

- Enforcing password policies, including length, complexity, and expiration periods.
- Ensuring secure storage and retrieval for passwords through encryption.
- Enabling secure password self-service for users to reset their passwords.

15.3.2 Alignment with Best Practices

15.3.2.1 The PMS shall adhere to best practices, such as:

- Requiring passwords to include a mix of uppercase, lowercase, numbers, and symbols, with at least 8-character password for accounts using MFA and 14-character for accounts not using MFA.
- Prohibiting reuse of the last three passwords.
- Encouraging the use of password managers to securely store and generate strong passwords.

COP TEMPLATE

15.3.3 Compliance Monitoring

15.3.3.1 Compliance with password policies shall be monitored by:

- Conducting regular audits of user accounts to ensure adherence to the password policy.
- Generating alerts for weak or compromised passwords using automated tools.
- Reviewing logs from the PMS for anomalies or unauthorised password changes.

15.3.4 Review of Password Management System

15.3.4.1 The PMS shall be reviewed annually as part of the overall IAM review process, and / or whenever changes occur, such as advancements in password management technologies or the emergence of new cyber security threats like password cracking techniques.

16.0 TECHNICAL VULNERABILITY

16.1 Vulnerability Management Procedure

NCII sector lead shall ensure its NCII entities are committed to managing technical vulnerabilities by establishing a robust Vulnerability Management Procedure (VMP). The VMP shall align with industry best practices and include compliance monitoring to ensure adherence to established protocols. Regular reviews and updates of the VMP shall be conducted to maintain effectiveness and support continuous improvement in vulnerability management.

16.1.1 Establishment of Vulnerability Management Procedure

16.1.1.1 The NCII entity shall establish a Vulnerability Management Procedure (VMP) following the vulnerability management lifecycle as follows:

- **Assess:** All systems connected to the NCII entity's network must undergo vulnerability scanning.
- **Prioritise:** Identified vulnerabilities must be prioritised, with critical vulnerabilities addressed first.
- **Remediate:** A process for remediating identified vulnerabilities must be established, with non-remediable vulnerabilities submitted through the vulnerability exception process.

CoP TEMPLATE

- **Monitor:** Security mailing list from the vendors may be subscribed to receive notifications of recently released patches and other software updates, and Common Vulnerabilities and Exposures (CVE) list data feeds for updates about newly disclosed vulnerabilities.

16.1.2 Alignment with Best Practices

16.1.2.1 The procedure shall align with industry standards and best practices such as NIST SP 800-40 Guide to Enterprise Patch Management Planning.

16.1.3 Compliance Monitoring

16.1.3.1 Compliance with the VMP shall be monitored through:

- Regular internal audits to verify adherence to established procedures.
- Reports that measure the effectiveness of vulnerability management activities.

16.1.4 Review and Updates

16.1.4.1 The VMP shall be reviewed and updated annually, to incorporate changes in cyber security threat landscapes or organisational structure, and when changes occur, such as new system implementations or regulatory updates.

16.2 Vulnerability Assessment

NCII sector lead shall ensure its NCII entities identify, evaluate, and mitigate security weaknesses within its IT infrastructure by establishing a Vulnerability Assessment Plan (VAP). The VAP shall guide the systematic execution of vulnerability assessments, enable effective monitoring and tracking of assessment activities, and ensure thorough evaluation of identified vulnerabilities. By maintaining a structured approach, the NCII entity can enhance its security posture, ensure compliance with industry standards, and strengthen resilience against evolving cyber risks.

16.2.1 Establishment of Vulnerability Assessment Plan

16.2.1.1 The NCII entity shall define a Vulnerability Assessment Plan (VAP) that outline the following:

- The scope of assessments, including networks, applications, systems, and devices.
- The frequency of assessments (monthly, quarterly, or after major updates).

COP TEMPLATE

- The tools and methods for identifying vulnerabilities, such as network scanners, penetration tests, and configuration reviews.
- The criteria for categorising vulnerabilities based on criticality and potential impact.

16.2.2 Conducting Vulnerability Assessment Plan

16.2.2.1 Vulnerability assessments shall be conducted in accordance with the VAP.

16.2.2.2 The assessments may be carried out through automated vulnerability scanning that utilises tools such as OpenVAS, and manual assessments to identify vulnerabilities that may not be detected by automated tools, including logical flaws and logic vulnerabilities.

16.2.2.3 The NCII entity shall ensure that vulnerability assessments shall be performed by authorised cyber security professionals, either in-house or through approved third-party experts, to ensure accuracy and reliability.

16.2.3 Monitor and Track

16.2.3.1 All identified vulnerabilities shall be managed and remediated through a structured risk-based remediation process, ensuring timely resolution and ongoing security compliance. The NCII entity shall:

- Monitor the vulnerabilities regularly to ensure their status (open, in-progress, resolved) is up to date.
- Continuously monitor vulnerability status (open, in-progress, resolved) to track remediation progress and ensure timely mitigation.
- Integrate threat intelligence feeds to assess vulnerabilities in real time, correlating identified risks with emerging cyber security threats to enhance situational awareness and response effectiveness.

CoP TEMPLATE

16.2.4 Evaluate

16.2.4.1 Identified vulnerabilities shall be evaluated using following methods:

- Determine their severity using standards like Common Vulnerability Scoring System (CVSS).
- Conduct cyber security risk assessment by evaluating the likelihood of exploitation and the potential consequences on the NCII entity confidentiality, integrity, and availability (CIA triad).
- Utilise threat intelligence feeds to gain insights into ongoing exploits or emerging attack vectors, enabling prioritisation vulnerabilities that are actively being targeted.
- Assess the value of the affected asset to the NCII entity to determine the level of priority for remediation. Appropriate mitigation and remediation measures shall be implemented based on the evaluation results to address the identified vulnerabilities in a timely manner.

16.2.5 Review and Reporting

16.2.5.1 The outcomes of vulnerability assessments and remediation shall be:

- Documented in detailed reports that include:
  - List of vulnerabilities detected.
  - Remediation steps taken.
  - Status updates on unresolved issues.
- Reviewed and presented to the relevant cyber security governance committee established for this purpose, as authorised by the management, during periodic review meetings to ensure accountability and drive necessary actions.

CoP TEMPLATE

17.0 CYBER SECURITY EVENT MANAGEMENT

17.1 Event Management

NCII sector lead shall ensure that its NCII entities establish and implement a Security Monitoring Procedure (SMP) to effectively detect, analyse, and respond to cyber security events. NCII entities must ensure full compliance with the SMP. Regular reviews and updates of the SMP shall be conducted to maintain its effectiveness, ensure alignment with evolving security standards and regulatory requirements, and continuously strengthen the organisation's overall cyber security posture.

17.1.1 Establishment of Security Monitoring Procedure (SMP)

17.1.1.1 The NCII entity shall establish a Security Monitoring Procedure (SMP) that outlines:

- The objectives of security monitoring, including real-time detection of potential cyber security threats, anomalies, and security breaches.
- The scope of monitoring, specifying critical systems, networks, applications, and databases.
- Selection and deployment of monitoring tools such as:
  - IDPS.
  - SIEM solutions.
  - Network and endpoint monitoring tools.
- Defined roles and responsibilities for security operations personnel, including cyber security incident detection, escalation, and response.
- Integration of the monitoring system with threat intelligence feeds to stay updated on evolving cyber security threats.
- Notification and escalation protocols to ensure timely reporting of cyber security incidents to the appropriate stakeholders.

17.1.2 Compliance Monitoring

17.1.2.1 Compliance with the SMP shall be monitored through:

- Regular audits to verify the consistent implementation of monitoring controls and tools.
- Continuous review of monitoring logs to identify gaps or deviations in adherence to the procedure.
- Use of key performance indicators (KPIs) such as:

CoP TEMPLATE

- Mean Time to Detect (MTTD) cyber security incidents.
- Mean Time to Respond (MTTR) to identified cyber security threats.
- Volume and type of events logged by the monitoring system.

- Assigning accountability to a Cyber Security Incident Response Team (CSIRT) or equivalent group for ensuring compliance.

17.1.3 Review of Security Monitoring Procedure

17.1.3.1 The SMP shall undergo regular reviews annually, and / or whenever necessary to maintain its effectiveness, through:

- Annual reviews to align the procedure with changes in organisational structure, emerging cyber security threat landscapes and industry standards and regulatory requirements.
- Triggered Reviews whenever significant changes occur, such as:
  - Adoption of new technologies or systems.
  - Major updates to existing infrastructure.

18.0 CYBER SECURITY INCIDENT MANAGEMENT

18.1 Cyber Security Incident Procedure and Handling

NCII sector lead shall ensure its NCII entities establish a robust Cyber Security Incident Management Procedure. This procedure shall enable the NCII entities to swiftly detect, respond to, mitigate, and recover from cyber security incidents while minimising damage and operational disruption. A well-defined incident management approach enhances incident response efficiency, reduces downtime, safeguards sensitive data, and strengthens the overall cyber security posture of the NCII entities.

18.1.1 Establishment of Cyber Security Incident Management Procedure

18.1.1.1 The NCII entity shall establish a Cyber Security Incident Management Procedure (CSIMP) to ensure effective detection, response, and resolution of cyber security incidents. The procedure shall include:

- Cyber Security Incident Response Plan Lifecycle:
  - **Plan**: Create documentation outlining all procedures required to manage a cyber security incident.

COP TEMPLATE

- **Detect**: Continuously monitor NCII entity's assets and analyse intelligence to determine if a cyber security incident has occurred.
- **Respond**: Implement the cyber security incident response plan to address, manage and recover from the cyber security incident.
- **Update**: Evaluate the effectiveness of the cyber security incident response plan, and make necessary updates based on the assessment.

- Roles and Responsibilities:
  - Establish a CSIRT Team or equivalent group which will be responsible for managing the cyber security incident;
  - Assign responsibilities to CSIRT Team or equivalent group;
  - Appointment of three (3) authorised persons responsible for cyber security incident notification as required in subsection 11(3) of Act 854 in the manner prescribed in the Directive of Chief Executive No. 1 - Notification of Cyber Security Incident; and
  - Define roles for stakeholders, including IT, legal, communications, and business units.
- Communication Protocols:
  - Establish internal and external communication channels, including notification to affected stakeholders, management, and regulatory bodies where applicable.

18.1.2 Response and Cyber Security Incident Handling

18.1.2.1 The NCII entity shall ensure cyber security incidents are responded to and handled in accordance with the CSIMP, compliance to the Act 854 and the Cyber Security (Notification of Cyber Security Incident) Regulations 2024 [*P.U. (A) 220/2024*] by implementing the following:

- **Cyber Security Incident Detection**:
  - Use tools like firewalls, intrusion detection systems (IDS), and endpoint protection solutions to detect potential cyber security incidents.

CoP TEMPLATE

- The NCII entity's authorised person must immediately notify cyber security incident that has or might have occurred as stated in subregulation 2(1) of P.U. (A) 220/2024 through email at cert@nc4.gov.my.
- Within six (6) hours from the time the cyber security incident comes to the knowledge of the NCII entity, the authorised person shall submit all necessary information, based on the requirement stated in the subregulation 2(2) of P.U. (A) 220/2024 through NC4's Portal at www.nc4.gov.my.

- **Cyber Security Incident Handling Process**:
  - **Initial Response:** Ensure timely triage and categorisation of the cyber security incident.
  - **Containment:** Take actions to minimise the impact of the cyber security incident, such as isolating affected systems or blocking malicious IP addresses.
  - **Eradication:** Remove the root cause of the cyber security incident, such as malware or compromised accounts.
  - **Recovery:** Restore affected systems and ensure normal operations with security enhancements to prevent recurrence.
- **Cyber Security Incident Escalation**:
  - Escalate cyber security incidents to higher authorities or external specialists based on the severity and complexity of the cyber security incident.
- **Documentation and Reporting**:
  - Maintain detailed logs of the cyber security incident, including timelines, affected systems, and actions taken.
  - Prepare cyber security incident reports for internal review and compliance purposes.
  - Within fourteen (14) days after the notification, the authorised person shall provide to the fullest extent practicable the supplementary information in the NC4's Portal, as required in subregulation 2(3) of P.U. (A) 220/2024.

CoP TEMPLATE

- The authorised person shall provide periodic updates on the reported cyber security incident as required by the Chief Executive, in accordance with subregulation 2(4) of P.U. (A) 220/2024.
- All report submissions to the Chief Executive of NACSA shall be made through the NC4 system, as stipulated in regulation 3 of P.U. (A) 220/2024. In the event of a disruption, communication shall follow the provisions outlined in paragraph 11 of the Directive of Chief Executive No. 1 - Notification of Cyber Security Incident.

- **Engagement with Third Parties**:
  - Engage external specialists, such as cyber security incident response consultants, where necessary.
  - Coordinate with law enforcement or regulators for cyber security incidents involving legal violations.

18.1.3 Review of Cyber Security Incident Management Procedure

18.1.3.1 The NCII entity shall conduct reviews of the CSIMP annually and / or whenever changes occur to ensure it remains relevant and effective, through:

- Annual Reviews:
  - Reassess the CSIMP annually to account for changes in technology, cyber security threats, and organisational structure.
- Post-Incident Reviews:
  - Conduct a review after significant cyber security incidents to identify strengths, weaknesses, and areas for improvement.
  - Use lessons learned from a cyber security incident or tabletop exercise to enhance the CSIMP.

18.1.3.2 The CSIMP shall be aligned with regulatory requirements and industry standards, including ISO/IEC 27035: Information Security Incident Management or NIST SP 800-61: Computer Security Incident Handling Guide.

CoP TEMPLATE

18.1.3.3 Reviews shall incorporate feedback from IT, legal, and other relevant stakeholders to continuously improve processes.

18.1.3.4 Version control for CSIMP review documentation shall be maintained to track changes and ensure proper dissemination.

19.0 BUSINESS CONTINUITY MANAGEMENT

19.1 Business Continuity Plan (BCP)

NCII sector lead shall ensure its NCII entities implement a Business Continuity Management (BCM) framework to maintain critical operations during disruptions caused by cyber security incidents, natural disasters, system failures, or other crises. The BCM framework shall include the development and maintenance of a Business Continuity Plan (BCP) and associated processes to enhance organizational resilience, minimize downtime, protect critical assets, and support swift recovery.

19.1.1 Establishment of Business Continuity Plan

19.1.1.1 The NCII entity shall establish a Business Continuity Plan (BCP) to ensure critical business functions continue during and after disruptive events. The BCP shall include the following elements:

- Cyber Security Risk Assessment and Business Impact Analysis (BIA):
  - Identify potential cyber security threats (cyber attacks, natural disasters, power failures) and assess their potential impact on business operations.
  - Prioritise critical functions and processes based on their impact on the NCII entity's objectives.
- Crisis Management Framework:
  - Define the structure of the Crisis Management Team (CMT) and their roles and responsibilities.
  - Include clear decision-making protocols and escalation processes.
- Recovery Strategies:
  - Outline strategies to recover critical functions, such as IT system and data recovery, supply chain continuity, and communication plans.

COP TEMPLATE

- Include alternate work arrangements (remote working or alternate office locations).

- Communication Plan:
  - Define internal and external communication procedures during a disruption.
  - Identify communication tools (email, SMS, collaboration platforms) to reach employees, stakeholders, and customers.
- Documentation and Accessibility:
  - Ensure the BCP is documented in detail and made accessible to relevant personnel.
  - Maintain both digital and hard copies stored securely in accessible locations.

19.1.2 Compliance Monitoring

19.1.2.1 The NCII entity shall ensure compliance with the BCP through the following measures:

- **Monitoring and Reporting**:
  - Regularly monitor adherence to BCP requirements across departments.
  - Generate periodic compliance reports for the review by relevant cyber security governance committee established for this purpose, as authorised by the management.
- **Audits and Inspections**:
  - Conduct scheduled and ad-hoc audits to verify compliance.
  - Ensure findings from audits are addressed and corrective actions are implemented promptly.
- **Stakeholder Awareness**:
  - Ensure that all employees and stakeholders understand their roles and responsibilities under the BCP.
  - Provide regular updates on BCP processes and requirements to key personnel.

COP TEMPLATE

19.1.3 Review of Business Continuity Plan

19.1.3.1 The NCII entity shall review the BCP annually and / or whenever necessary such as after significant events like major cyber security incidents or organisational changes.

19.1.3.2 During the review process, input from key stakeholders, including employees, suppliers, and customers should be collected.

19.1.3.3 BCP document should be updated to reflect changes, ensuring proper version control and dissemination to relevant parties.

19.2 Testing and Simulation

NCII sector lead shall ensure its NCII entities maintain a practical, effective, and well-prepared BCP. Regular testing and simulations shall be conducted to validate the BCP, strengthen cyber security incident response capabilities, and enhance overall preparedness. A robust and well-tested BCP ensures operational stability, regulatory compliance, and long-term resilience of the NCII entity.

19.2.1 Conducting Scenario-Based Testing and Simulations

19.2.1.1 The NCII entity shall conduct scenario-based testing and simulation exercises on an annual basis or when required by the relevant cyber security governance committee established for this purpose, as authorised by the management. The exercise shall include all relevant stakeholders to ensure collaboration between the cyber security and business continuity teams.

19.2.1.2 Realistic scenarios shall be designed that reflect potential disruptions, such as:

- Cyber security incidents (ransomware attacks or data breaches).
- Natural disasters (floods, earthquakes).
- Critical system failures (server outages or power cuts).
- Supply chain disruptions.

19.2.1.3 The NCII entity should conduct various types of simulations to assess the effectiveness of its BCP and cyber security incident response capabilities, including:

- **Tabletop Exercises:** Facilitate discussions on how teams would handle specific cyber security incidents and other crises.

CoP TEMPLATE

- **Live Simulations:** Conduct full-scale simulations, including cyber attack drills to test response times, coordination, and recovery measures.
- **Red Teaming & Penetration Testing:** Assess cyber security defences by simulating real-world cyber attacks.

19.2.1.4 Record and document the cyber security incident response performance and observations during simulations to identify strengths, weaknesses, and improvement areas.

19.2.2 Reporting and Documentation

19.2.2.1 The outcomes of testing and simulations shall be documented and shared with relevant stakeholders through:

- **Post-Test Reports:**
  - Include findings, cyber resilience performance metrics, and areas needing improvement in post-test reports.
  - Highlight the effectiveness of cyber security incident response strategies and any gaps that were identified.
- **Cyber Security Governance Committee Review:**
  - Present test results to the relevant cyber security governance committee established for this purpose, as authorised by the management, for review and approval of necessary actions.
  - Align findings with regulatory requirements and sector-wide cyber security strategies.
- **Action Plans:**
  - Develop and implement corrective action plans to address identified cyber security and business continuity gaps.
  - Assign ownership and deadlines for implementing improvements.

CoP TEMPLATE

20.0 [OTHER SECTOR-SPECIFIC REQUIREMENTS]

The NCII sector lead shall develop and incorporate sector-specific cyber security requirements to address the unique operational environments, regulatory obligations, and risk landscapes of their respective sectors. The examples provided in this section are for guidance purposes only, and NCII sector leads may exclude any examples that are not relevant to their sector. NCII sector leads must define tailored cyber security requirements that effectively mitigate sector-specific cyber security threats and ensure compliance with applicable laws and regulations. These customised requirements will enhance the cyber resilience of NCII entities, protect critical infrastructures, and align practices with industry best standards.

20.1 Operational Technology (OT) Security Requirements

20.1.1 OT security requirements are applicable to sectors relying on Industrial Control Systems (ICS), Supervisory Control and Data Acquisition (SCADA), and IoT.

20.1.2 The requirement shall include network segmentation, access control, real-time monitoring, and secure remote access for OT environments.

20.2 E-commerce Security Requirements

20.2.1 The NCII entity shall provide a secure e-commerce platform by implementing the following:

- Secure coding practices, regular update and patch CMS platforms, deploy anti-DDoS solutions, and utilize bot detection and prevention measures to protect against web vulnerabilities, fraud, and service disruptions; and
- Compliance with PCI-DSS by using secure payment gateways with encryption and tokenization to ensure online payment security.

CoP TEMPLATE

21.0 MONITORING AND COMPLIANCE

NCII sector lead shall ensure its NCII entities establish clear processes for monitoring, documenting, and reporting compliance with the CoP. This includes defining procedures for reviewing and updating the CoP to maintain cyber security resilience and operational effectiveness. Compliance activities shall be systematically tracked and reported to relevant stakeholders, with regular reviews and updates to align with evolving cyber security threats and regulatory requirements

21.1 Compliance Monitoring Reports

21.1.1 Compliance with the CoP shall be tracked through regular reports on key cyber security and business continuity metrics.

21.1.2 Reports shall include indicators such as:

- Percentage of staff completing cyber security training within the required timeframe.
- Effectiveness of cyber security incident response, including the percentage of cyber security incidents resolved within defined Service Level Agreements (SLA).
- Implementation status of security controls and BCP measures across the NCII entity.

21.1.3 Compliance reports shall undergo review and approval by the relevant cyber security governance committee established for this purpose, as authorised by the management, to assess adherence to CoP requirements.

21.2 Review and Continuous Improvement

21.2.1 This CoP shall be reviewed annually or following significant events, such as major cyber security incidents, regulatory changes, or industry best practice updates.

21.2.2 The relevant cyber security governance committee established for this purpose, as authorised by the management, shall be responsible for updating policies, controls, and training programs to reflect emerging risks and evolving compliance requirements.

CoP TEMPLATE

21.2.3 Action plans shall be developed to address identified gaps, with clear ownership and timelines for implementation.

22.0 REFERENCES

NCII sector lead should provide references to relevant policies, regulations, and industry standards that support the implementation of this CoP. By aligning with established cyber security frameworks and best practices, NCII entities can enhance compliance, strengthen security controls, and ensure consistency with national and international guidelines.

- **Government of Malaysia.** (2024). *Cyber Security (Notification of Cyber Security Incident) Regulations 2024.* Kuala Lumpur: Percetakan Nasional Malaysia Berhad.

- **Government of Malaysia.** (2024). *Cyber Security (Period for Cyber Security Risk Assessment and Audit) Regulations 2024.* Kuala Lumpur: Percetakan Nasional Malaysia Berhad.

- **International Organization for Standardization (ISO).** (2022). *ISO 27001:2022, Information Security, cybersecurity and privacy protection – Information security management systems – Requirements.* ISO.

- **International Organization for Standardization (ISO).** (2022). *ISO 27002:2022, Information Security, cybersecurity and privacy protection – Information security controls.* ISO.

- **National Cyber Security Agency (NACSA).** (2024). *National Cyber Security Baseline (NCSB) version 1.3.* Retrieved from https://www.nacsa.gov.my/doc/NationalCyberSecurityBaselinev1.3.pdf

- **National Institute of Standards and Technology (NIST).** (2024) The NIST Cybersecurity Framework (CSF) 2.0. NIST Cybersecurity White Paper (CSWP)

- **Parliament of Malaysia.** (2024). ***Cyber Security Act 2024*** *[Act 854].* Kuala Lumpur: Percetakan Nasional Malaysia Berhad.

CoP TEMPLATE

23.0 APPENDICES

NCII sector lead should provide supporting materials, and templates to assist NCII entities in implementing and maintaining the requirements outlined in this CoP. By utilizing these resources, NCII entities can standardise procedures, enhance compliance, and improve overall cyber security resilience. Well-structured appendices ensure that NCII entities have access to practical tools for effective management of cyber security practices, including risk management, cyber security incident response, and security operations.

CoP TEMPLATE

Appendix A: Code of Practice Checklist

**NCII sector leads are required to update the 'Reference in CoP' column to align with their respective CoPs.*

NO.	SOURCE	REQUIREMENT	REFERENCE IN COP*	YES/NO (√ / X)
1.	Cyber Security Act 2024 [*Act 854*]	***Subsection 25 (2)*** *The national critical information infrastructure sector lead shall, in preparing the code of practice under subsection (1), consider among others the following matters:* *(a) the functions of the relevant national critical information infrastructure entities;* *(b) provisions relating to cyber security under any other written law applicable to the national critical information infrastructure sector lead;* *(c) the views of the relevant national critical information infrastructure entities; and* *(d) the views of the relevant regulatory authority, if any, which the national critical information infrastructure entity is subject to.*	N/A	
2.	National Cyber Security Baseline (NCSB)	***3.1.1.1*** *The organisation shall establish a cyber security policy.*	5.1.1.1	
3.	NCSB	***3.1.1.2*** *The cyber security policy shall be aligned with industry best practices.*	5.1.2.1	
4.	NCSB	***3.1.1.3*** *The cyber security policy shall be applied across the organisation.*	5.1.3.1	
5.	NCSB	***3.1.1.4*** *The cyber security policy shall be reviewed annually and / or when changes are required.*	5.1.4.1	
6.	NCSB	***3.1.1.5*** *The cyber security policy shall be proactively communicated to all relevant stakeholders.*	5.1.5.1	
7.	NCSB	***3.1.2.1*** *The organisation shall develop cyber security objectives that are consistent with its cyber security policy.*	5.2.1.1	
8.	NCSB	***3.1.2.2*** *The cyber security objectives shall be communicated to relevant stakeholders.*	5.2.2.1	
9.	NCSB	***3.1.2.3*** *The cyber security objectives shall be continuously monitored, tracked and reported annually to the management.*	5.2.3.1	
10.	NCSB	***3.2.1.1*** *The organisation shall define cyber security roles and responsibilities.*	6.1.1.1	

11.	NCSB	***3.2.1.2*** *The defined cyber security roles and responsibilities shall be communicated to all relevant stakeholders.*	6.1.2.1	
12.	NCSB	***3.2.1.3*** *Resources shall be allocated by the defined cyber security roles and responsibilities.*	6.1.3.1	
13.	NCSB	***3.2.1.4*** *Allocated resources shall be reviewed annually and / or when changes are required.*	6.1.4.1	
14.	NCSB	***3.2.2.1*** *The organisation shall establish contacts with relevant authorities and special interest groups.*	6.2.1.1	
15.	NCSB	***3.2.2.2*** *The contact information for relevant authorities and special interest groups shall be communicated to the stakeholders.*	6.2.2.1	
16.	NCSB	***3.2.2.3*** *The contact information shall be reviewed annually and / or when changes are required.*	6.2.3.1	
17.	NCSB	***3.2.3.1*** *The organisation shall develop and establish a cyber security awareness training plan.*	6.3.1.1	
18.	NCSB	***3.2.3.2*** *Cyber security awareness training programs shall be conducted across the organisation.*	6.3.2.1	
19.	NCSB	***3.2.3.3*** *The effectiveness of cyber security awareness training programs shall be evaluated upon completion.*	6.3.3.1	
20.	NCSB	***3.3.1.1*** *The organisation shall develop and establish an IT acceptable use policy.*	7.1.1.1	
21.	NCSB	***3.3.1.2*** *The IT acceptable use policy shall be applied across the organisation.*	7.1.2.1	
22.	NCSB	***3.3.1.3*** *The IT acceptable use policy shall be reviewed when changes are required.*	7.1.3.1	
23.	NCSB	***3.3.2.1*** *The organisation shall establish a cyber security audit plan.*	7.2.1.1	
24.	NCSB	***3.3.2.2*** *The cyber security audit plan shall be approved by the management.*	7.2.2.1	
25.	Act 854	***Paragraph 22(1)(b)*** *A national critical information infrastructure entity shall within the period as may be prescribed cause to be carried out an audit by an auditor approved by the Chief Executive to determine the compliance of the national critical information infrastructure entity with this Act.*	7.2.3.1	

COP TEMPLATE

26.	Cyber Security (Period for Cyber Security Risk Assessment and Audit) Regulations 2024 [*P.U. (A) 219/2024*] NCSB	***Subregulation 3(b)*** *A national critical information infrastructure entity owned or operated a national critical information infrastructure shall carrying out an audit at least once in every two years or at such higher frequency as may be directed by the Chief Executive in any particular case.* ***3.3.2.3*** *Cyber security audits shall be conducted at least biennially by certified auditors.*	7.2.3.1	
27.	NCSB	***3.3.2.4*** *Audit findings shall be reported to the management and relevant stakeholders.*	7.2.4.2	
28.	Act 854	***Subsection 22(2)*** *The national critical information infrastructure entity shall, within the period of thirty days after the completion of the cyber security risk assessment or audit under subsection (1), submit the cyber security risk assessment report or audit report to the Chief Executive.*	7.2.4.3	
29.	NCSB	***3.3.2.5*** *Any non-compliances identified during the audit shall be resolved in a timely manner and reported to the management and relevant stakeholders.*	7.2.5.1 7.2.5.3	
30.	NCSB	***3.3.3.1*** *The organisation shall define a supply chain management policy.*	7.3.1.1	
31.	Cyber Security (Licensing of Cyber Security Service Provider) Regulations 2024 [*P.U. (A) 221/2024*]	*NCII entities engaging external cyber security service providers for managed security operation centre monitoring service and penetration testing service shall appoint NACSA-licensed cyber security providers, except when the providers are a Government entity, an individual (other than a company) to its related company, or when the computer or computer systemin respect of which the cyber security service is provided is located outside Malaysia.*	7.3.1.2	
32.	NCSB	***3.3.3.2*** *External service providers shall be identified and documented.*	7.3.2.1	
33.	NCSB	***3.3.3.3*** *The supply chain management policy and the list of external providers shall be reviewed annually.*	7.3.3.1	
34.	NCSB	***3.4.1.1*** *The organisation shall establish an IT assets inventory.*	8.1.1.1	
35.	NCSB	***3.4.1.2*** *The IT assets inventory shall be maintained.*	8.1.2.1	

COMMENTARY TEMPLATE

36.	NCSB	***3.4.1.3*** *The IT assets shall be classified and assigned to the appropriate ownership.*	8.1.3.1 8.1.3.4	
37.	NCSB	***3.4.1.4*** *The IT assets inventory shall be reviewed annually and/ or when changes are required.*	8.1.4.1	
38.	NCSB	***3.4.2.1*** *The organisation shall establish a capacity management plan.*	8.2.1.1	
39.	NCSB	***3.4.2.2*** *Resource utilisation shall be tracked and monitored.*	8.2.2.1	
40.	NCSB	***3.4.2.3*** *Resource utilisation results shall be reviewed annually and the necessary resource forecasts shall be taken.*	8.2.3.1	
41.	NCSB	***3.4.2.4*** *Performance test shall be conducted prior to system go-live or whenever required to validate and confirm the resilience of the system's performance.*	8.2.4.1	
42.	NCSB	***3.5.1.1*** *The organisation shall establish cyber security risk assessment process.*	9.1.1.1	
43.	Directive of Chief Executive No. 5 - Cyber Security Risk Assessment	***Paragraph 8*** *Proses penilaian risiko keselamatan siber yang dibuat hendaklah meliputi perkara seperti yang dinyatakan di bawah perenggan 8 Arahan ini.*	9.1.3.3 9.1.4.2	
44.	NCSB	***3.5.1.2*** *The cyber security risk assessment process shall be aligned with best practices.*	9.1.2.1	
45.	NCSB	***3.5.1.3*** *The cyber security risk assessments shall be conducted annually and / or when changes are required.*	9.1.3.1	
46.	P.U. (A) 219/2024	***Subregulation 3(a)*** *A national critical information infrastructure entity owned or operated a national critical information infrastructure shall conduct a cyber security risk assessment at least once a year.*	9.1.3.1	
47.	Directive of Chief Executive No. 5 - Cyber Security Risk Assessment	***Paragraph 7*** *Skop penilaian risiko keselamatan siber yang dibuat hendaklah meliputi penilaian risiko terhadap sistem atau sistem komputer entiti infrastruktur maklumat kritikal negara.*	9.1.3.2	
48.	NCSB	***3.5.1.4*** *The results of the cyber security risk assessment shall be documented and reported to the management and / or relevant stakeholders.*	9.1.4.1	
49.	Act 854	***Subsection 22(2)***	9.1.4.1	

		The national critical information infrastructure entity shall, within the period of thirty days after the completion of the cyber security risk assessment or audit under subsection (1), submit the cyber security risk assessment report or audit report to the Chief Executive.		
50.	Directive of Chief Executive No. 5 - Cyber Security Risk Assessment	***Paragraph 9*** *Laporan penilaian risiko keselamatan siber yang disediakan hendaklah meliputi perkara seperti yang dinyatakan di bawah perenggan 9 Arahan ini.*	9.1.4.4	
51.	NCSB	***3.5.1.5*** *The identified risks shall be prioritized for treatment.*	9.1.5.1	
52.	NCSB	***3.5.2.1*** *The organisation shall formulate a risk treatment plan.*	9.2.1.1	
53.	NCSB	***3.5.2.2*** *The risk treatment plan shall be approved by the risk owner or the management.*	9.2.2.1	
54.	NCSB	***3.5.2.3*** *The approved risk treatment plan shall be implemented.*	9.2.3.1	
55.	NCSB	***3.5.2.4*** *The results of the risk treatment shall be documented and reported to the management and / or relevant stakeholders.*	9.2.4.1	
56.	NCSB	***3.6.1.1*** *The organisation shall establish a change management procedure for managing changes to information processing facilities, information systems, and other relevant components.*	10.1.1.1	
57.	NCSB	***3.6.1.2*** *The change management procedure shall be applied across the organisation.*	10.1.2.1	
58.	NCSB	***3.6.1.3*** *Authorisation must be obtained before implementing any changes to information processing facilities, information systems, or other relevant components.*	10.1.3.1	
59.	NCSB	***3.6.1.4*** *The change management procedure shall be reviewed annually and / or when changes are required.*	10.1.4.1	
60.	NCSB	***3.7.1.1*** *The organisation shall apply data leakage prevention (DLP) solution across the organisation.*	11.1.1.1	
61.	NCSB	***3.7.1.2*** *The DLP solution shall be maintained regularly.*	11.1.2.1	
62.	NCSB	***3.7.1.3*** *The DLP logs shall be integrated with tools such as SIEM, that enhance threat detection, analysis and incident response capabilities.*	11.1.3.1	

CONFIDENTIAL

63.	NCSB	***3.7.2.1*** *The organisation shall define data privacy and protection procedure.*	11.2.1.1	
64.	NCSB	***3.7.2.2*** *The data privacy and protection procedure shall be aligned with legal and regulatory requirements.*	11.2.2.1	
65.	NCSB	***3.7.2.3*** *The data privacy and protection procedure shall be applied across the organisation.*	11.2.3.1	
66.	NCSB	***3.7.2.4*** *Compliance with the data privacy and protection procedure shall be regularly monitored.*	11.2.4.1	
67.	NCSB	***3.7.2.5*** *The data privacy and protection procedure shall be reviewed annually and / or when changes are required.*	11.2.5.1	
68.	NCSB	***3.7.3.1*** *The organisation shall establish cyber security guidelines for software and system / applications development.*	11.3.1.1	
69.	NCSB	***3.7.3.2*** *The cyber security for guidelines software and system / applications development is implemented.*	11.3.2.1	
70.	NCSB	***3.7.3.3*** *The cyber security requirements shall be identified, specified and approved by the management when developing software and system / applications.*	11.3.3.1	
71.	NCSB	***3.7.3.4*** *The organisation shall conduct security testing on software and system / applications before their deployment in a production environment.*	11.3.4.1	
72.	NCSB	***3.7.4.1*** *The organisation shall establish procedures for the configuration of hardware, software, services, and networks.*	11.4.1.1.	
73.	NCSB	***3.7.4.2*** *The configuration shall be monitored and reviewed regularly and any updates or installations shall be based on the management's approval.*	11.4.2.1 11.4.2.3	
74.	NCSB	***3.7.4.3*** *The configuration logs shall be recorded and maintained.*	11.4.3.1 11.4.3.2	
75.	NCSB	***3.8.1.1*** *The organisation shall establish a Non-Disclosure Agreements (NDAs).*	12.1.1.1	
76.	NCSB	***3.8.1.2*** *The NDAs shall be signed by all relevant parties.*	12.1.2.1	

CONFIDENTIAL

77.	NCSB	***3.8.1.3*** *The organisation shall monitor compliance with the signed NDAs and any instances of non-compliance shall be reported to the management.*	12.1.3.1 12.1.3.2	
78.	NCSB	***3.9.1.1*** *The organisation shall establish a physical security procedure.*	13.1.1.1	
79.	NCSB	***3.9.1.2*** *The physical security procedure shall be aligned with best practices.*	13.1.2.1	
80.	NCSB	***3.9.1.3*** *The physical security procedure shall be applied across the organisation.*	13.1.3.1	
81.	NCSB	***3.9.1.4*** *Compliance with the physical security procedure shall be regularly monitored.*	13.1.4.1	
82.	NCSB	***3.9.1.5*** *The physical security procedure shall be reviewed annually and / or when changes are required.*	13.1.5.1	
83.	NCSB	***3.9.2.1*** *The organisation shall establish security perimeters to prevent unauthorised physical access, damage and interference to the organisation's information.*	13.2.1.1	
84.	NCSB	***3.9.2.2*** *The organisation shall continuously monitor the premise to prevent unauthorised physical access.*	13.2.2.1	
85.	NCSB	***3.9.2.3*** *The organisation shall design and implement protections against physical and environmental threats to reduce the consequences of unwanted events.*	13.2.3.1	
86.	NCSB	***3.10.1.1*** *The organisation shall establish network security policy and procedure.*	14.1.1.1	
87.	NCSB	***3.10.1.2*** *The network security policy and procedure shall be approved by the management.*	14.1.2.1	
88.	NCSB	***3.10.1.3*** *The network security policy and procedure shall be aligned with industry best practices.*	14.1.3.1	
89.	NCSB	***3.10.1.4*** *Compliance with the network security policy and procedure shall be regularly monitored.*	14.1.4.1	
90.	NCSB	***3.10.1.5*** *The network security policy and procedure shall be reviewed annually and / or when changes are required.*	14.1.5.1	
91.	NCSB	***3.10.2.1*** *The organisation shall define the physical and logical network diagrams.*	14.2.1.1	

92.	NCSB	***3.10.2.2*** *The network diagrams shall be aligned with best practices.*	14.2.2.1	
93.	NCSB	***3.10.2.3*** *The network diagrams shall consist of advanced security controls such as next-generation firewalls (NGFW), intrusion detection and prevention systems (IDPS), security information and event management (SIEM) systems, and zero trust architecture.*	14.2.3.1	
94.	NCSB	***3.10.2.4*** *The network diagrams shall be reviewed when changes are required.*	14.2.4.1	
95.	NCSB	***3.10.3.1*** *The organisation shall implement firewall rules to control traffic between the network segments.*	14.3.1.1	
96.	NCSB	***3.10.3.2*** *The organisation shall implement network threat detection capability to enable early detection and response to suspicious network activities.*	14.3.2.1	
97.	NCSB	***3.10.3.3*** *The organisation shall implement NAC solutions across the organisation to enforce access policies.*	14.3.3.1	
98.	NCSB	***3.10.3.4*** *The organisation shall review the firewall rules, network threat detection capability, and NAC solutions annually and / or when changes are required.*	14.3.4.1	
99.	NCSB	***3.10.4.1*** *The organisation shall implement malware detection and prevention software.*	14.4.1.1	
100.	NCSB	***3.10.4.2*** *Logs from the malware detection and prevention software shall be integrated with tools such as SIEM, that enable centralised monitoring and correlation of events to detect sophisticated attacks.*	14.4.2.1	
101.	NCSB	***3.10.4.3*** *Logs from the malware detection and prevention software shall be regularly analysed and evaluated.*	14.4.3.1	
102.	NCSB	***3.11.1.1*** *The organisation shall establish identity and access management procedure that incorporates Multi-Factor Authentication (MFA).*	15.1.1.1	
103.	NCSB	***3.11.1.2*** *The identity and access management procedure shall be approved by the management.*	15.1.2.1	
104.	NCSB	***3.11.1.3*** *Compliance with the identity and access management procedure including the provision, revocation, and modification of identities shall be regularly monitored.*	15.1.3.1	

SOFTWARE

105.	NCSB	***3.11.1.4*** *The identity and access management procedure shall be reviewed annually and / or when changes are required.*	15.1.4.1	
106.	NCSB	***3.11.2.1*** *The organisation shall segregate the duties and responsibilities of employees based on their roles.*	15.2.1.1	
107.	NCSB	***3.11.2.2*** *Roles shall be defined and provisioned to minimise access problems in the event of role removal or reassigned.*	15.2.2.1	
108.	NCSB	***3.11.2.3*** *The segregation of duties of employees shall be reviewed annually and / or when changes are required.*	15.2.3.1	
109.	NCSB	***3.11.3.1*** *The organisation shall establish a password management system.*	15.3.1.1	
110.	NCSB	***3.11.3.2*** *The password management system shall be aligned with best practices.*	15.3.2.1	
111.	NCSB	***3.11.3.3*** *Compliance with the password management system shall be regularly monitored.*	15.3.3.1	
112.	NCSB	***3.11.3.4*** *The password management system shall be reviewed annually and / or when changes are required.*	15.3.4.1	
113.	NCSB	***3.12.1.1*** *The organisation shall establish a vulnerability management procedure.*	16.1.1.1	
114.	NCSB	***3.12.1.2*** *The vulnerability management procedure shall be aligned with best practices.*	16.1.2.1	
115.	NCSB	***3.12.1.3*** *Compliance with the vulnerability management procedure shall be regularly monitored.*	16.1.3.1	
116.	NCSB	***3.12.1.4*** *The vulnerability management procedure shall be reviewed annually and / or when changes are required.*	16.1.4.1	
117.	NCSB	***3.12.2.1*** *The organisation shall establish a vulnerability assessment plan.*	16.2.1.1	
118.	NCSB	***3.12.2.2*** *Vulnerability assessments shall be conducted as per the established plan.*	16.2.2.1	
119.	NCSB	***3.12.2.3*** *The identified vulnerabilities shall be monitored and tracked.*	16.2.3.1	

COP TEMPLATE

120.	NCSB	***3.12.2.4*** *Identified vulnerabilities shall be evaluated and appropriate measures shall be taken to address the vulnerabilities.*	16.2.4.1	
121.	NCSB	***3.12.2.5*** *The outcomes of vulnerability assessments and remediation shall be reviewed and reported to the relevant stakeholders.*	16.2.5.1	
122.	NCSB	***3.13.1.1*** *The organisation shall establish a security monitoring procedure.*	17.1.1.1	
123.	NCSB	***3.13.1.2*** *Compliance with the security monitoring procedure shall be regularly monitored.*	17.1.2.1	
124.	NCSB	***3.13.1.3*** *The security monitoring procedure shall be reviewed annually and / or when changes are required.*	17.1.3.1	
125.	NCSB	***3.14.1.1*** *The organisation shall establish a cyber security incident management procedure.*	18.1.1.1	
126.	Directive of Chief Executive No. 1 - Notification of Cyber Security Incident	***Paragraph 7*** *Bagi tujuan pemberitahuan insiden keselamatan siber, setiap entiti infrastruktur maklumat kritikal negara hendaklah mengemukakan butiran tiga (3) orang yang diberi kuasa seperti yang dinyatakan di bawah perenggan 7 dan 8 Arahan ini.*	18.1.1.1	
127.	NCSB	***3.14.1.2*** *Cyber security incidents shall be responded to and handled accordingly based on established incident management procedure.*	18.1.2.1	
128.	Cyber Security (Notification of Cyber Security Incidents) Regulations 2024 [*P.U. (A) 220/2024*]	***Subregulation 2(1)*** *An authorised person of a national critical information infrastructure entity shall immediately, by electronic means, give a notification of a cyber security incident that has or might have occurred as provided under section 23 of the Act when the cyber security incident comes to the knowledge of the national critical information infrastructure entity.*	18.1.2.1	
129.	Directive of Chief Executive No. 1 - Notification of Cyber Security Incident	***Paragraph 9*** *Pemberitahuan dengan segera, melalui cara elektronik, mengenai suatu insiden keselamatan siber yang telah atau mungkin telah berlaku di bawah subperaturan 2(1) P.U.(A) 220 hendaklah dibuat melalui e-mel ke alamat elektronik: cert@nc4.gov.my*	18.1.2.1	
130.	P.U. (A) 220/2024	***Subregulation 2(2)*** *Within six hours from the time the cyber security incident comes to the knowledge of the national critical*	18.1.2.1	

COPY TEMPLATE

		information infrastructure entity, the authorized person shall submit the following particulars of information as prescribed in the subregulation 2(2).		
131.	P.U. (A) 220/2024	***Subregulation 2(3)*** *Within fourteen days after the notification referred to in subregulation (1), the authorized person shall provide to the fullest extent practicable the following supplementary information as prescribed in the subregulation 2(3).*	18.1.2.1	
132.	P.U. (A) 220/2024	***Subregulation 2(4)*** *The authorised person of the national critical information infrastructure entity shall provide, from time to time, further updates on the cyber security incident as the Chief Executive may require.*	18.1.2.1	
133.	P.U. (A) 220/2024	***Regulation 3*** *The submission of information under subregulations 2(2) and (3) shall be made through the National Cyber Coordination and Command Centre System or in the event of disruption in the National Cyber Coordination and Command Centre System, by the communication as may be determined by the Chief Executive.*	18.1.2.1	
134.	Directive of Chief Executive No. 1 - Notification of Cyber Security Incident	***Paragraph 11*** *Jika sekiranya berlaku gangguan yang menyebabkan pengemukaan maklumat di bawah subperaturan 2(2) atau subperaturan 2(3) P.U. (A) 220/2024 tidak boleh dibuat melalui Sistem Pusat Penyelarasan dan Kawalan Siber Negara, entiti infrastruktur maklumat kritikal negara itu hendaklah mengemukakan butir-butir yang dikehendaki tersebut dengan cara seperti yang dinyatakan di bawah perenggan 11 Arahan ini.*	18.1.2.1	
135.	NCSB	***3.14.1.3*** *The cyber security incident management procedure shall be reviewed annually and / or when changes are required.*	18.1.3.1	
136.	NCSB	***3.15.1.1*** *The organisation shall establish a business continuity plan.*	19.1.1.1	
137.	NCSB	***3.15.1.2*** *Compliance with the business continuity plan shall be regularly monitored.*	19.1.2.1	
138.	NCSB	***3.15.1.3*** *The business continuity plan shall be reviewed annually and / or when changes are required.*	19.1.3.1	
139.	NCSB	***3.15.2.1*** *The organisation shall conduct scenario-based testing and simulation exercises on an annual basis or when required by the management.*	19.2.1.1	

CONFIDENTIAL